Sicurezza dei sistemi informativi - appello 16 giugno 2022

1. Cosa è AES-192?
    a. Un algoritmo di crittografia asimmetrica
    b. Un algoritmo di hash con digest a 192 bit
    c. Un algoritmo di crittografia simmetrica a blocchi con chiave e blocco da 192 bit
    d. Un algoritmo di crittografia simmetrica di tipo stream con chiave e nonce da 192 bit
    e. Nessuna delle precedenti

2. Spiegare quali sono i principali approcci metodolodici per la stima dei rischi, in altre parole, come dai dati di assessment e di framing si ottengono gli impatti. Per ognuno di questi approcci spiegare da quali dati si parte, quali informazioni vengono derivate o usate e come si stimano, infine, gli impatti dei rischi

3. Spiegare cosa. Sono il GCM e l'H-MAC, quali proprietà di sicurezza permettono di garantire e, brevemente, come vengono implementati. Indicare quando ha senso usarli e quali sono i vantaggi che portano ad utilizzarli

4. Spiegare cosa è il processo di reverse engineering e come gli strumenti noti come disassembler e decompiler permettono di effettuarlo su binari. In particolare, indicare cosa questi tool producono in output e quali sono le loro principali limitazioni.

5. Cosa è un a KDF?
    a. È una funzione che trasforma chiavi crittografiche speudo-random in chiavi più forti usando l'entropia ottenuta da un sale crittografico generato mediante un processo random
    b. È una funzione che cifra un numero elevato di volte una password con un sale random per generare delle chiavi crittografiche forti
    c. È una funzione che permette di rallentare attaccanti che intendono svolgere dictionary attack obbligando la ripetizione di operazioni crittografiche su un sale per un numero elevato di iterazioni
    d. È una funzione che permette di ottenere dati pseudo-casuali forti a partire da stringhe di testo

6. Un'azienda dotata dalla sua rete privata aziendale vuole esporre al pubblico due servizi (HTML e posta elettronica) da due server aziendali (fisici, di proprietà dell'azienda). Approfittando delle modifiche, hanno deciso di dividere la rete aziendale in due parti a diversi livelli di sicurezza. La parte rede della rete aziendale a livello di sicurezz più elevato dovrà attraversare la parte di rete a livello di sicurezza intermedio per poter accedere ad internet.
   Progettare una soluzione che permetta di implementare una politica di autorizzazione di rete, indicando quali security control vorreste usare e come questi sarebbero collegati alle varie reti e ai due server

7. Elencare tutte le informazioni ed i dati che vengono scambiati mediante il TLS Handshake Protocol. Per ognuno di essi indicare come lo scambio viene effettuato e a cosa servono ai fini del protocollo TLS i dati scambiati

1. Dati le seguenti tecniche e scenari di attacco,
    a. Shadow server,
    b. Packet sniffing,
    c. Man-at-the-end
    d. APT

   Spiegare come funzionano, indicare brevemente gli obiettivi che si potrebbero ottenere, e indicare possibili contromisure e controlli di sicurezza potrebbero limitarli
2. Spiegare cosa è il GDPR, quale è il suo obiettivo e indicare almeno 3 principi che lo caratterizzano
3. Cosa è Chacha20 256?
    a. La versione completa di un algoritmo di crittografia simmetrica di tipo stream con chiave 256 bit.
    b. Un algoritmo di crittografia simmetrica di tipo stream con blocco da 128 bit e chiave da 256 bit.
    c. Un algoritmo di crittografia simmetrica a blocchi con blocco da 128 bit e chiave da 256 bit.
    d. Un algoritmo di crittogragia simmetrica a blocchi con blocco da 256 bit e chiave 256 bit.
    e. Nessuna delle precedenti.
4. Spiegare come funziona IPsec (v2) ESP in tunnel mode e quali trasformazioni vengono fatte ai pacchetti IP.

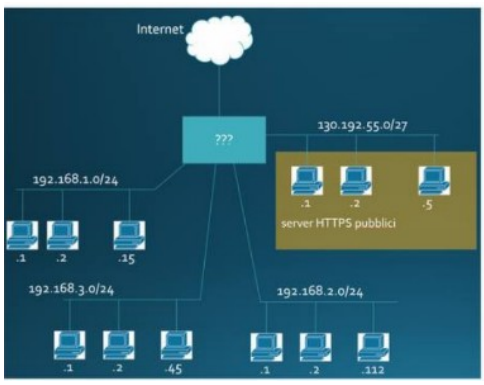
   Descrivere uno scenario di utilizzo, le ipotesi perché possa essere attuato e una tecnica per autenticare le parti ed uno specifico metodo di autenticazione ritenuto particolarmente sicuro (motivando).

   Indicare quali proprietà di sicurezza possono essere applicate con questa tecnica. Per ognuna delle proprietà indicate, riportare se sono obbligatorie o opzionali e a quale parte del pacchetto IP originale si applicano.
5. Indicare e motivare brevemente quale controllo, tecnologia o architettura di sicurezza utilizzereste nel caso fosse necessario implementare della policy di sicurezza per:
    a. Impedire che dall'esterno della rete (es. internet) possano lanciare un attacco che sfrutti una vulnerabilità non ancora corretta (patch) ad un web service aziendale.
    b. Proteggere un server web dagli attacchi nella Top10 di OWASP
    c. Gestire da riga di comando un apparato di rete
    d. Permettere ad alcuni host, tutti noti e descritti mediante una lista di indirizzi IP, riescano a comunicare con un server interno
    e. Proteggere la rete aziendale ed un server che deve essere raggiungibile anche da chiunque da internet
    f. Permettere agli utenti nella sede di Torino di un'azienda di comunicare in maniera sicura con un'altra sede della stessa azienda di Bologna
6. Cosa è una KDF?
    a. È una finzione che permette di rallentare attaccanti che intendono svolgere dictionary attack perché li obbliga a chifrare password e sale per un numero elevato di iterazioni
    b. È una funzione usata per trasformare una password in dati casuali usando una stringa segreta detta sale.
    c. È una funzione che permette di generare chiavi crittografiche a partire da un sale crittografico random
    d. È una funzione che cifra un numero elevato di volte una password ed un sale random per generare delle chiavi crittografiche forti
    e. È una funzione che trasforma dati che non sono pseudo-random in chiavi forti usando l'entropia ottenuta da un sale crittografico generato mediante un processo random.
7. Spiegare cosa è e quale problema permette di risolvere l'Extensible Authentication Protocol (EAP) e quale importante servizio fornisce per rendere possibile la comunicazione.

   Inoltre, spiegare cosa è l'EAP-TLS e valutarne l'efficacia.

1. Un client e un server del TLS 1.2 negoziano la seguente ciphersuite
   TLS_DHE_RSA_WITH_3DES_EDE_CBC_SHA256
   Spiegare cosa vuol dire ognuna delle componenti principali della ciphersuite e su quale proprietà di sicurezza e TLS ha influenza. Spiegare brevemente cosa accadrà durante l'handshake protocol per lo scambio di chiavi a autenticazione del server. Quale è la parte più critica di questa ciphersuite e perché?
2. Bob e Alice sono colleghi presso la SSI Inc. Alice invia a Bob:
   - Il suo certificato X.509 a chiave pubblica firmato dalla CA aziendale;
   - Un file firmato con la chiave privata corrispondente alla pubblica presente nel certificato.

   Assumete che la SSI Inc sia dotata di una infrastruttura a chiave pubblica completa, gestita correttamente sia al livello di registrazione che di funzionalità informatica. Riportare tutti i passi che Bob deve fare (o un tool al suo posto) per poter stabilire che la firma sia valida.
3. Riportare 4 aspetti relativi all'implementazione di servizi che rispettino Privacy by design secondo il GDPR e una breve spiegazione. Spiegare chi è e che ruolo ha il DPO.
4. Spiegare come funziona l'autenticazione basata sulle password ripetibili. Riportare i principali problemi che bisogna affrontare lato client, lato server, nel canale di comunicazione e quelle generali e le conseguenti mitigazioni.
5. Indicare quali delle seguenti affermazioni sul SYN Interceptor e SYN Monitor sono vere (più di una). Attenzione: risposte sbagliate danno punteggi negativi.
   a. Il SYN Interceptor è meno efficace del SYN Monitor;
   b. Il SYN Monitor è meno efficace del SYN Interceptor;
   c. Non alterano il three-way handshake ma inviano pacchetti al posto del server:
   d. Cambiano il three-way handshake per evitare SYN flooding inviando l'hash del sequence number;
   e. Il SYN Interceptor risponde al posto del server. Contatta il server stabilendo una connessione solo se il three-way handshake ha successo;
   f. Servono entrambi a mitigare gli attacchi di tipo SYN flooding;
   g. Il SYN Monitor risponde al posto del server. Contatta il server stabilendo una connessione solo se il three-way handshake ha successo;
   h. Nessuno dei due risolve completamente il problema del SYN flooding.
6. Un'azienda ha una rete organizzata come riportata sotto:



   E vuole implementare la seguente politica di sicurezza:
   a. Nessuna restrizione interna ad ognuna delle 3 sottoreti

b. Il server interno 192.168.1.1 deve essere raggiungibili dalle sottoreti .2 e .3
c. Il server interno 192.168.2.3 deve essere raggiungibile dalla sottorete .1
d. Nessuna sottorete interna (.1*, .2*, .3*) deve essere raggiungibile dall'esterno;
e. Tutti gli host interni alle sottoreti .1 e .2 possono raggiungere Internet
f. Tutti gli host interni alle sottoreti .3 non possono raggiungere Internet
g. I server con indirizzi pubblici devono essere raggiungibili da Internet ma solo su un insieme di URL note (immaginate siano salvate su un file come $ur1, $url2, …)

Indicate quali controlli di sicurezza preventiva abilitereste sull'elemento al bordo (contrassegnato con ???) per implementare i requisiti e quale architettura state applicando. Riportate inoltre le regole corrispondenti (può essere pseudo-linguaggio di configurazione ma deve riportare tutti i campi essenziali necessari).

PARTE DI QUIZ

- [x] a. Negli standard di sicurezza moderni i requisiti funzionali vengono separati da quelli qualitativi. ✔
- [ ] b. I dati giudiziari non sono ritenuti dati sensibili.
- [x] c. Secondo il Regolamento 2016/679, il Data Protection Officer ha anche il compito di decidere come proteggere, dal punto di vista tecnico, i dati personali. ✖
- [x] d. Per il GDPR, ogni entità che tratta dati personali o sensibili deve svolgere un PIA (Privacy Impact Assessment). Seguire alcune delle indicazioni dell'RMF potrebbe essere utile a questo scopo. ✔
- [ ] e. Il principio della Full functionality del GDPR implica la necessità di applicare le funzionalità di protezioni più efficaci.
- [ ] f. Secondo lo standard ISO/SAE 21434, bisogna svolgere la TARA, che è un altro modo per indicare la fase che nell'RMF è definita risk assessment.
- [ ] g. I Common Criteria specificano la metodologia di valutazione (detta CEM) per questo gli esperti ritengono che renda più semplice il processo di certificazione.
- [ ] h. Lo standard ISO 27000 richiede di essere compliant anche con lo standard RMF del NIST.
- [x] i. Secondo le ultime leggi comunitarie, l'ENISA ha anche il compito di supportare la gestione operativa degli incidenti informatici coordinando gli sforzi tra gli Stati membri. ✔

Le risposte corrette sono:
Negli standard di sicurezza moderni i requisiti funzionali vengono separati da quelli qualitativi.,

Secondo lo standard ISO/SAE 21434, bisogna svolgere la TARA, che è un altro modo per indicare la fase che nell'RMF è definita risk assessment.,

Per il GDPR, ogni entità che tratta dati personali o sensibili deve svolgere un PIA (Privacy Impact Assessment). Seguire alcune delle indicazioni dell'RMF potrebbe essere utile a questo scopo.,

Secondo le ultime leggi comunitarie, l'ENISA ha anche il compito di supportare la gestione operativa degli incidenti informatici coordinando gli sforzi tra gli Stati membri.

Domande dell'appello di oggi

- [ ] a. Secondo uno studio di Verizon, gli esterni sono i principali "attori" in attacchi informatici, gli interni invece sono irrilevanti e possono essere ignorati.
- [ ] b. Un attacco di tipo APT compromette in maniera avanzata e costante i sistemi rendendoli inutilizzabili nel minor tempo possibile.
- [x] c. I money mule trasformano soldi virtuali (es. su conti correnti) in denaro in contanti. ✔
- [x] d. Gli attacchi DDoS sono meno preoccupanti degli attacchi ransomware perché le contromisure (filtro degli attaccanti, ridondanza, sovradimensionamento) sono più efficaci. ✖
- [ ] e. Il processo di configurazione di dispositivi di sicurezza non presenta alcun rischio per la sicurezza informatica.
- [x] f. Il whaling è una forma di phishing che punta agli utenti più importanti di un'organizzazione. ✔
- [x] g. Con attacchi di tipo pretexting, gli attaccanti creano un contesto complesso e/o si inseriscono in conversazioni precedenti per poter ingannare le vittime. ✔
- [x] h. Secondo un recente trend, per compromettere determinate aziende, gli attaccanti preferiscono compromettere partner più deboli della Supply Chain invece di affrontare le aziende target. ✔
- [ ] i. Un attacco di tipo MatE non può essere lanciato contro un'autovettura.

Le risposte corrette sono:
Secondo un recente trend, per compromettere determinate aziende, gli attaccanti preferiscono compromettere partner più deboli della Supply Chain invece di affrontare le aziende target.,

I money mule trasformano soldi virtuali (es. su conti correnti) in denaro in contanti.,

Il whaling è una forma di phishing che punta agli utenti più importanti di un'organizzazione.,

Con attacchi di tipo pretexting, gli attaccanti creano un contesto complesso e/o si inseriscono in conversazioni precedenti per poter ingannare le vittime.

- [x] a. L'obfuscation serve a rendere il codice incomprensibile contro attacchi/tool statici e dinamici. ✖
- [x] b. DEP è una tecnica di protezione dagli attacchi implementata dal sistema operativo per rendere più difficile sfruttare i buffer overflow. ✔
- [x] c. S/MIME definisce come devono essere strutturati i messaggi di posta elettronica che implementino confidenzialità e autenticazione dei dati + integrità (o entrambi). ✔
- [ ] d. Ret2Libc è una tecnica di attacco al software che sfrutta vulnerabilità per invocare funzioni o eseguire pezzi di codice presi da librerie standard.
- [ ] e. Lo standard PKCS#12 definisce il formato delle CRL.
- [x] f. La potency è una misura astratta pensata per valutare l'efficacia delle protezioni contro gli attacchi MatE al software. ✔
- [ ] g. HELO mail.polito.it seguito da STARTLS fa partire la creazione di un canale sicuro per inviare messaggi di posta SMTP al Mail Transfer Agent.
- [ ] h. Le firma PAdES sono di tipo enveloped.
- [x] i. Un disassmbler è uno strumento che, dato qualunque programma binario, lo analizza e ne genera una rappresentazione assembly semanticamente equivalente e completa. ✖

Le risposte corrette sono:
Le firma PAdES sono di tipo enveloped., S/MIME definisce come devono essere strutturati i messaggi di posta elettronica che implementino confidenzialità e autenticazione dei dati + integrità (o entrambi).

,

La potency è una misura astratta pensata per valutare l'efficacia delle protezioni contro gli attacchi MatE al software.,

Ret2Libc è una tecnica di attacco al software che sfrutta vulnerabilità per invocare funzioni o eseguire pezzi di codice presi da librerie standard.,

DEP è una tecnica di protezione dagli attacchi implementata dal sistema operativo per rendere più difficile sfruttare i buffer overflow.

- [ ] a. I computer quantistici comprometteranno in maniera grave gli attuali algoritmi di crittografia simmetrica. Dovremo cambiarli tutti a breve.
- [x] b. I numeri pseudo-casuali sono generati con processi deterministici. ✔
- [ ] c. Gli algoritmi di crittografia simmetrica di tipo ARX sono teoricamente veloci ma non sono implementabili con processori attuali.
- [ ] d. La crittografia a curve ellittiche, non lavorando con campi modulari e numeri primi, rende più sicuri gli algoritmi di firma e scambio di chiavi asimmetrici perché resiste agli attacchi basati su computer quantistici.
- [x] e. L'algoritmo di Diffie-Hellman è resistente allo sniffing. ✔
- [x] f. Sfruttare il teorema cinese del resto permette di velocizzare le operazioni di crittografia asimmetrica necessarie per RSA. ✔
- [x] g. L'algoritmo di Shor serve a fattorizzare numeri interi con complessità logaritmica ma è implementabile solo su computer quantistici. ✔
- [ ] h. Crare un canale sicuro (es. TLS) con i server della Certification Authority è necessario per evitare gli attacchi contro le CRL.
- [x] i. Una Qualified Electronic Signature è una firma digitale calcolata con una chiave privata la cui chiave pubblica è certificata in un QC, mediante un dispositivo per la generazione di firme sicuro e con Time stamp ottenuti da TSA fidate. ✔

Le risposte corrette sono:
L'algoritmo di Diffie-Hellman è resistente allo sniffing.,

Sfruttare il teorema cinese del resto permette di velocizzare le operazioni di crittografia asimmetrica necessarie per RSA.,

Una Qualified Electronic Signature è una firma digitale calcolata con una chiave privata la cui chiave pubblica è certificata in un QC, mediante un dispositivo per la generazione di firme sicuro e con Time stamp ottenuti da TSA fidate.,

L'algoritmo di Shor serve a fattorizzare numeri interi con complessità logaritmica ma è implementabile solo su computer quantistici.,

I numeri pseudo-casuali sono generati con processi deterministici.

- [x] a. Nelle aziende che hanno un SOC, questo si occupa anche di gestire la "compliance" con la ISO 27000. ✔
- [ ] b. Un firewall configurato come dual-homed gateway è considerato molto flessibile.
- [x] c. Secondo i principi inderogabili di Bellovin/Cheswick, il FW deve essere un sistema altamente sicuro esso stesso. ✔
- [ ] d. Una regola come "iptables -A INPUT -p tcp --dport 80 -j ACCEPT" potrebbe essere parte di una politica di tipo whitelisting implementata correttamente.
- [ ] e. Un application-level filter può essere usato per gestire le connessioni di protocolli applicativi per conto dei client.
- [x] f. Un forward proxy viene di solito usato per inoltrare le richieste dei client interni ad un'azienda al vero server esterno, dopo averli autenticati e verificato che siano autorizzati. ✖
- [x] g. Un Incident Response Team dovrebbe essere addestrato ad intervenire anche in caso di attacchi di tipo Distributed Denial of Service ✔
- [ ] h. Un Intrusion Prevention System previene gli attacchi che i suoi componenti di detection sono in grado di rilevare.
- [x] i. Tra i compiti previsti per un HIDS ci sono: analizzare log del sistema operativo, monitorare che non vengano modificati file importanti e avvertire l'IDS director in caso di problemi. ✔

Le risposte corrette sono:
Secondo i principi inderogabili di Bellovin/Cheswick, il FW deve essere un sistema altamente sicuro esso stesso.,

Una regola come "iptables -A INPUT -p tcp --dport 80 -j ACCEPT" potrebbe essere parte di una politica di tipo whitelisting implementata correttamente.,

Tra i compiti previsti per un HIDS ci sono: analizzare log del sistema operativo, monitorare che non vengano modificati file importanti e avvertire l'IDS director in caso di problemi.,

Nelle aziende che hanno un SOC, questo si occupa anche di gestire la "compliance" con la ISO 27000.,

Un Incident Response Team dovrebbe essere addestrato ad intervenire anche in caso di attacchi di tipo Distributed Denial of Service

- [ ] a. In SSH, le chiavi dei server devono essere memorizzate in chiaro nella stessa cartella dei certificati (~/.rhosts).
- [ ] b. Nel caso di MAC calcolato senza AE, il TLS non garantisce protezione da cancellazione e filtro.
- [x] c. Il trailer di ESP serve al destinatario a verificare l'integrità e l'autenticazione dei dati del payload di un pacchetto IP. ✔
- [ ] d. Gli utenti di una Basic VPN devono installare o configurare i client sulle loro macchine personali.
- [ ] e. IKE mette a disposizione metodi per lo scambio di chiavi esclusivamente dinamici basati su algoritmi di crittografia asimmetrica.
- [x] f. l SA Database contiene l'elenco delle Security Association attive, le quali riportano algoritmi, chiavi e tutti i parametri crittografici necessari a stabilire un canale. ✔
- [ ] g. DTLS è più sicuro ed efficiente di TLS perché non deve gestire le connessioni logiche a livello 4 dello stack ISO/OSI.
- [x] h. l'Handshake Protocol del TLS1.3 è ritenuto più efficiente perché implementa 0-RTT e non effettua alcuna compressione dei dati. ✔
- [x] i. In TLS, le chiavi usate per cifrare e calcolare i MAC vengono generate ogni volta che viene eseguito l'Handshake Protocol. ✔

Le risposte corrette sono:
l SA Database contiene l'elenco delle Security Association attive, le quali riportano algoritmi, chiavi e tutti i parametri crittografici necessari a stabilire un canale.,

Il trailer di ESP serve al destinatario a verificare l'integrità e l'autenticazione dei dati del payload di un pacchetto IP.,

In TLS, le chiavi usate per cifrare e calcolare i MAC vengono generate ogni volta che viene eseguito l'Handshake Protocol.,

l'Handshake Protocol del TLS1.3 è ritenuto più efficiente perché implementa 0-RTT e non effettua alcuna compressione dei dati.

PARTE SCRITTO

(Domanda BONUS)
Vi trovate a cena in un ristorante che non espone menu cartaceo ma un QR Code da cui scaricare una versione digitale.

Spiegate brevemente quali rischi esistono e che operazioni fareste per mitigarli.

Il QR code presente potrebbe reindirizzare l'utente su qualche sito malevolo, che potrebbe attuare tattiche di phishing tramite l'uso di shadow-server (per esempio nel sito del ristorante potrebbero essere presenti collegamenti a siti cloni di popolari social network che potrebbero essere usati per rubare le credenziali degli utenti).

Per mitigare il rischio l'utente potrebbe controllare l'URL contenuto nel QR code prima di navigare e controllare che non punti a qualche sito sospetto, e non cliccare direttamente su collegamenti social dalla pagina raggiunta dal QR code, ma se si è interessati ai profili del ristorante sarebbe meglio raggiungerli direttamente dalle rispettive applicazioni/siti

Domanda 2

Completo

Punteggio max.: 10,00

Contrassegna domanda

Descrivete il Digital Authentication Model (NIST SP800.63B), gli attori, le fasi che prevede e le singole operazioni che è necessario svolgere per stabilire una sessione autenticata.
Spiegate come le fasi di questo modello astratto vengono implementate in FIDO2 (NOTA: non spiegate come funziona FIDO2, dovete associare le operazioni del protocollo FIDO2 ad attori, fasi e operazioni previste dal modello astratto).
Indicate quali sono gli aspetti che fanno ritenere FIDO2 un metodo di autenticazione forte.

Nel Digital Authentication Model identifichiamo 4 attori principali

- L'utente che vuole autenticarsi
- Un CSP, server che mantiene e rilascia le credenziali
- Un verifier
- Un relying party, servizio con il quale l'utente vuole stabilire una sessione autenticata

Il processo si svolge nel modo seguente

- Se l'utente non è registrato è detto supplicant,

Avete una rete con migliaia di nodi che devono connettersi tramite cavo o wireless. La rete è divisa in una decina di sedi fisiche diverse.

Spiegate cosa implementereste per autenticare gli utenti prima di accedere alla rete, quali protocolli serve configurare (e per quale scopo) e quali elementi (HW/SW) sono necessari.

Nel contesto descritto, ogni sede deve avere distribuiti al suo interno una certa quantità di access-point wifi e switch. Gli utenti prima di collegarsi alla rete dovranno essere autenticati, e per farlo si possono usare dei protocolli di autenticazione come

- PAP -> Non lo userei, password e nome utente inviati in chiaro

- CHAP e EAP sono meccanismi più sicuri che permettono di fare autenticare gli utenti con i NAS

Primo problema : gli utenti potrebbero essere molti, e gestire le credenziali su ogni NAS è un lavoro complesso e dispendioso

Si potrebbe quindi implementare un RADIUS server che permette di [illegible] le credenziali salvate in un unico pu[illegible] al quale i NAS possono connettersi p[illegible] identificare l'utente di

Spiegare precisamente tutto quello che viene negoziato durante il TLS Handshake Protocol.

Indicare per ognuno degli elementi negoziati come questo verrà usato per stabilire e mantenere un canale sicuro, sottolineando gli algoritmi ed i metodi crittografici necessari e le proprietà di sicurezza garantite.

Sicurezza dei Sistemi Informativi 18-06-2025

Domanda 1

Spiegare cosa è il processo di Reverse Engineering applicato al software.

Indicare e classificare i tipi di tool che possono essere usati, i tipi di analisi che permettono e gli artefatti che possono essere ottenuti.

Domanda 2

Spiegare precisamente tutto quello che viene negoziato durante il TLS Handshake Protocol (v1.2+).

Indicare, per ognuno degli elementi negoziati:

- le proprietà di sicurezza di canale o le funzionalità per cui questo verrà usato;
- quali metodi crittografici usati;
- quale è, se esiste, la controparte in IPsec.

Domanda 3

Avete notato che il vostro PC Windows ha iniziato ad essere particolarmente lento e le ventole di CPU e GPU sono sempre al massimo.Aprendo Task Manager e leggendo la lista dei processi, ne appare uno dal nome strano, crypt0jack.exe.

Spiegate cosa potrebbe essere successo e come vi comportereste per risolvere questa situazione.

Cosa è successo:

Come risolvere:

Domanda 4

Spiegare cosa sono i Common Criteria e a cosa servono. All'interno di questo contesto, spiegare cosa sono i Protection Profile e perchésono utili.

Infine, discutere cosa è il CEM e come si integra con i Common Criteria.

Common Criteria:

Protection Profile:

CEM:

Scegli le affermazioni vere dalla lista:

(selezionando una risposta esatta si ha un punteggio positivo, selezionando una risposta sbagliata si ha un punteggio negativo, non selezionare una risposta dà 0)

- [x] a. I packet filter sono mediamente più veloci degli application-level filter. ✔
- [ ] b. Un network-based IDS monitora il traffico delle sottoreti di un'azienda, non può essere usato per identificare attacchi provenienti da Internet.
- [x] c. In un'architettura di tipo '*screened subnet*' si può mascherare la rete interna ma potrebbero essere necessarie funzionalità di NAT. ✔
- [ ] d. Gli IDS avanzati, basati su AI, permettono di identificare e reagire alle minacce in maniera più efficace rispetto a quelli tradizionali (basati sulle analisi statistiche).
- [x] e. In un SOC dovrebbero esserci esperti di analisi forense, perché il SOC deve includere tutte le figure professionali relative alla sicurezza informatica. ✔
- [x] f. Quando un'azienda viene attaccata e vengono "exfiltrati" dei dati, c'è il rischio di violazioni del GDPR. ✔
- [x] g. Le regole di un firewall sono un esempio di politica di autorizzazione. ✔
- [ ] h. Un WAF posto in modalità stealth davanti ad un server, è in grado di filtrare anche il traffico di applicazioni web cifrate mediante TLS.

a. Un Protection Profile definisce le regole di valutazione di una specifica categoria di prodotti, permette quindi a chi richiede una certificazione di concentrarsi su un security target specifico.

b. Uno Disassembler può essere usato per analizzare a run-time lo stato dei registri di un binario in esecuzione.

c. La Data Execution Prevention evita che possano essere eseguiti attacchi di buffer overflow che richiedono di eseguire codice dallo Stack. ✔

d. Le tecniche di anti-tampering servono a rendere incomprensibile il codice per evitare che si riesca a modificarlo. ✘

e. L'Information Security Management System (ISMS) permette di valutare quanto bene uno specifico prodotto (TOE) gestisce i dati aziendali.

f. Una certificazione di sicurezza aumenta la nostra fiducia nel prodotto certificato perché sappiamo che una apposita entità terza ha verificato che determinate proprietà di sicurezza siano effettivamente soddisfatte. ✔

g. Le tecniche di protezione remota sono più efficaci di quelle locali perché non saturano le risorse computazionali delle macchine che eseguono la specifica copia del software da proteggere.

h. Il Trusted Computer System Evaluation Criteria prevede un processo di certificazione moderno, ripetibile, snello e relativamente economico.

i. L'oggetto della valutazione di un processo di certificazione è una precisa combinazione di hardware e software ed è scorretto estendere la valutazione "per analogia" ad altre configurazioni. ✔

Scegli le affermazioni vere dalla lista:

(selezionando una risposta esatta si ha un punteggio positivo, selezionando una risposta sbagliata si ha un punteggio negativo, non selezionare una risposta dà 0)

a. Il traffico scambiato con una ciphers TLS_ECDHE_RSA_WITH_AES_128_G può essere accelerato solo se un HS sia SHA256 sia AES128.

b. L'OCSP mi permette di identificare tutte le firme non valide perché riporta il momento in cui il certificato è stato revocato.

c. Il problema matematico alla base dell'algoritmo di firma ECDSA è vulnerabile ad attacchi fatti con computer quantistici. ✔

d. Un certificato digitale di un utente che passi tutte le verifiche crittografiche correttamente, va scartato se il certificato della CA che lo ha emesso è stato revocato perché la chiave (della CA) è stata compromessa prima della sua emissione (del certificato dell'utente). ✔

e. L'algoritmo di Shor renderà attaccabili le firme digitali calcolate con gli algoritmi della crittografia post-quantum.

f. Un certificato X.509 di tipo Diffie Hellman riporterà tre parametri: il numero primo *p*, il generatore *g* e $p^x \bmod g$, dove *x* è il parametro privato del possessore del certificato.

g. Il contenuto di un documento firmato di tipo PAdES può essere letto solo da lettori di pdf in grado di estrarre e verificare la firma digitale. ✘

h. Un documento contenente una macro (es. Word) può essere firmato, ma i dati che verranno visualizzati non sono necessariamente quelli che sono stati firmati. ✔

i. Dato un documento che deve essere firmato da *n* firmatari, se si scegliesse di usare firme parallele la verifica richiederebbe in media meno tempo rispetto al caso in cui si scegliesse l'uso di firme sequenziali. ✔

Scegli le affermazioni vere dalla lista:

(selezionando una risposta esatta si ha un punteggio positivo, selezionando una risposta sbagliata si ha un punteggio negativo, non selezionare una risposta dà 0)

a. I CRA simmetrici sono resistenti allo sniffing. ✔

b. Nel Digital Authentication Model del NIST, il Claimant deve eseguire un protocollo di autenticazione con un Verifier su richiesta di un Relying Party. ✔

c. Zero-Knowledge Password Proof è, nonostante il nome, un esempio di passwordless authentication.

d. Il token FIDO2 è in grado di eseguire una procedura di CRA asimmetrico con un backend FIDO presente sul server. ✔

e. I sistemi biometrici (es. mediante dispositivo personale) se usati come ulteriori fattori di autenticazione rendono l'autenticazione più sicura. ✔

f. L'uso di un OTP è obbligatorio se bisogna implementare la multi-factor authentication.

g. In Kerberos, gli utenti ricevono dal Ticket Granting Server le chiavi simmetriche dei servizi (Ks) che hanno richiesto.

h. Uno dei principali problemi dell'uso di sistemi biometrici è la non sostituibilità delle credenziali compromesse. ✔

i. Un dictionary attack, a parità di tempo a disposizione, ha una maggiore probabilità di identificare le password degli utenti rispetto ad un approccio a forza bruta, considerando che statisticamente molti scelgono password deboli. ✔

- [x] a. A parità di bit delle chiavi, la crittografia a curve ellittiche permette di ottenere un livello di resistenza maggiore rispetto alla crittografia asimmetrica tradizionale (campi modulo *n*). ✔
- [x] b. A parità di dimensione del plaintext, cifrando con AES128-ECB si devono trasferire sempre meno dati rispetto ad AES128-CBC. ✔
- [x] c. Gli algoritmi di Hash vengono usati come Pseudo Random Function per generare le chiavi che garantiscono confidenzialità e integrità+autenticazione nel TLS. ✔
- [ ] d. Se l'ultimo blocco di dati cifrato con DES termina con 0x1324354505050505 (esadecimale) verrà accettato correttamente sia con che senza l'opzione *-no-pad* (OpenSSL).
- [x] e. È buona prassi rinnovare spesso le chiavi crittografiche simmetriche se si devono cifrare grosse quantità di dati perché, se non venissero rinnovate, gli attaccanti potrebbero ottenere informazioni statistiche utili ad attaccare la confidenzialità dei dati con esse cifrate. ✔
- [ ] f. Quando si usano algoritmi asimmetrici, l'operazione matematica svolta per cifrare con la chiave pubblica è la stessa che si usa quando si decifra con la chiave privata (= si usa la stessa formula con gli stessi parametri).
- [ ] g. L'attacco Heartbleed contro il TLS permette di ottenere la chiave privata del certificato del server TLS.
- [ ] h. Le key derivation function sono inefficienti, il numero di iterazioni non deve essere aumentato oltre 10000 per evitare di penalizzare le normali procedure di autenticazione.
- [x] i. Gli algoritmi di tipo stream sono attaccabili: la loro confidenzialità può essere violata desincronizzando i flussi di dati cifrati un bit alla volta. ✖

- [ ] a. I server RADIUS non sono in grado di fare da proxy, quelli di DIAMETER invece sì.
- [x] b. PPP serve ad incapsulare pacchetti di livello 3 per trasferimenti punto-punto. ✔
- [ ] c. Il protocollo RADIUS inoltra messaggi EAP senza modificarli.
- [x] d. Se si usa 802.1x, gli AP non devono necessariamente gestire l'autenticazione degli utenti. ✔
- [x] e. Il protocollo RADIUS incorpora metodi di protezione della confidenzialità dei pacchetti insufficienti. ✗ ✓
- [x] f. EAP è un "middleware" che permette di usare diversi tipi di autenticazione con diversi tipi di protocolli di comunicazione di livello 2. ✔
- [ ] g. Per come è progettato, EAP richiede frequenti cambiamenti allo standard, in pratica ogni volta che è necessario aggiungere un nuovo tipo di autenticazione.
- [ ] h. In ambito PPP, se usati correttamente, PAP e CHAP sono ancora considerati metodi di autenticazione forti.
- [ ] i. Eduroam non richiede la federazione delle istituzioni, perché l'autenticazione viene svolta direttamente dal server della propria istituzione.

Spiegare cosa è un trattamento dei dati e quali proprietà devono essere garantite, secondo il GDPR, per ogni trattamento.

Spiegare che ruolo hanno e quali sono le principali funzioni di responsabili e incaricati del trattamento.

Ruolo e funzioni di responsabili

Ruolo e funzioni di incaricati

Spiegare quale è il requisito che differenzia la classe B dalla classe A nel sistema di certificazione ITSEC

Indicare cosa è e cosa prevede il modello Man-at-the-End per gli attacchi al software. Spiegare in cosa si differenzia dal Man-in-the-Middle di solito usato per i protocolli crittografici. Infine, descrivere come si possono mitigare questi attacchi?

Modello Man-at-the-End

Differenze da Man-in-the-Middle

Come mitigare

Considerate i seguenti tipi di scansione. Spiegate, per ognuno di essi, quali informazioni permette di ottenere. Indicate come le scansioni vengono eseguite in pratica e discutete della possibilità che vengano identificate da sistemi di monitoring.

Identificazione versioni e OS

Informazioni che permette di ottenere<

Come viene eseguita

Identificazione da sistemi di monitoring

Tecniche basate su flag

Informazioni che permettono di ottenere

Come vengono eseguite

Identificazione da sistemi di monitoring<

Host discovery<

Informazioni che permette di ottenere

Come viene eseguita

Identificazione da sistemi di monitoring

Port scanning

Informazioni che permette di ottenere

Come viene eseguita

Identificazione da sistemi di monitoring

Fase dell'analisi del rischio

> Spiegate a cosa serve un Time Stamp e chi lo genera. Indicare un caso in cui il Time Stamp è indispensabile.

Spiegare a cosa serve il protocollo Diffie-Hellman (DH). Descrivere i dati usati (e le relazioni tra essi), le fasi da cui è composto tale protocollo e le operazioni matematiche da svolgere. Spiegare perché viene ritenuto sicuro (indicare una lunghezza minima in bit). Quale è l'attacco più importante contro questo protocollo?

Descrizione protocollo

Perché è ritenuto sicuro

Lunghezza minima in bit

L'attacco più importante

> Un'azienda vuole sviluppare un gateway che, senza alcun intervento umano e senza la necessità di alcuna configurazione esplicita, stabilisca una comunicazione sicura con un altro gateway. L'obiettivo è fornire a dei suoi partner (che non hanno competenze di cybersecurity) un dispositivo, fisicamente presente nella loro rete, che permetta di stabilire una VPN-IPsec tra le rispettive reti aziendali (cioè, quella dell'azienda che sviluppa il gateway e quella del parnter che usa il gateway). Viene spiegato ai partner che "dopo che entrambe le schede Ethernet vengono connesse alla rete, appena accesso il gateway fa partire un demone IKE configurato con autenticazione di tipo pre-shared key e successivamente protegge tutto il traffico tra le due reti mediante IPsec". Spiegate cosa vuol dire la frase precedente, cosa è IKE ed in che cosa consiste l'autenticazione di tipo pre-shared key. Riportate quale è, a vostro parere, il rischio maggiore di questa soluzione indicando se questa soluzione sarebbe accettabile in un contesto in cui tutti i dipendenti dell'azienda partner (che riceve il gateway) fossero tutti sono fidati? Motivate la risposta.

Quali soluzioni potrebbero essere adottate per mitigare il rischio appena identificato? (almeno due)

Significato frase riportata in precedenza

Il rischio maggiore

Questa soluzione sarebbe accettabile? Motivate

Soluzioni per mitigare il rischio (almeno due)

Esame Sicurezza dei Sistemi Informativi 14-02-2025

Domanda 1

Spiegare cosa è il Risk Management Framework del NIST e quali sono gli obiettivi di tale framework.Elencare e descrivere le fasi e alcune delle operazioni potrebbero essere svolte in ognuna di esse.

Spiegare cosa è l'Enterprise Patch Management (NIST SP 800-40) quali sono i suoi obiettivi e citate due aspetti rilevanti (concetti, strategie,considerazioni di sicurezza)

RMF: descrizione e obiettivi:

Fasi e relativa descrizione:

EPM: descrizione e obiettivi:

due aspetti rilevanti:

Domanda 2 BONUS 3 PT

Avete ricevuto la seguente mail. Valutate se ci sono rischi e motivate la vostra risposta (nell'ellissi in figura è riportata la URL effettiva).

Buonasera a tutti,

i risultati dell'esame del 27/1/25 sono stati pubblicati sul portale (sezione materiale didattico, cartella /esami)
https://didattica.polito.it/pls/portal30/sviluppo.pagina_corso_2023.main?t=3

https://didattica.p0lito.it/pls/portal30/sviluppo.pagina_corso_2023.main?t=3

I compiti potranno essere visionati lunedì 7/2/25

https://didattica.polito.it/VClass/correzione_esami

https://didattica.polito.it/VClass/correzione_esami

Saluti,
Aldo

****
Appello : 01UDUOV - Sicurezza dei sistemi informativi
del : 27/01/2025

****
Politecnico di Torino
Gestione Didattica
Prenotazione Esami
****

Domanda 3

Spiegare cosa si intende per protezione di canale e protezione di messaggio, indicando quando è più opportuno utilizzare l'una o l'altra.

Indicare un esempio di protocollo che implementi protezione di canale e uno che implementi protezione di messaggio. Per entrambi i protocolli scelti, elencate le proprietà di sicurezza che garantisce e in che modo queste vengono garantite.

definizione di protezione di canale e quando usarla:

Definizione di protezione di messaggio e quando usarla:

protocollo di protezione di canale

proprietà e modo per garantirla:

protocollo di protezione di messaggio

proprietà e modo per garantirla:

Domanda 4

Spiegate come funziona l'attacco di Kaminski e perché considerato molto pericoloso e avanzato delle precedenti tipologie di attacco eperché l'impatto è potenzialmente molto grave.

Indicate quale mitigazione si sta mettendo in atto e descrivete brevemente pro e contro.

Descrizione attacco di Kaminski:

perché è pericoloso e più avanzato:

l'impatto e conseguenze:

Mitigazioni:

Sicurezza dei Sistemi Informativi 18-06-2025

Domanda 1

Spiegare cosa è il processo di Reverse Engineering applicato al software.

Indicare e classificare i tipi di tool che possono essere usati, i tipi di analisi che permettono e gli artefatti che possono essere ottenuti.

Domanda 2

Spiegare precisamente tutto quello che viene negoziato durante il TLS Handshake Protocol (v1.2+).

Indicare, per ognuno degli elementi negoziati:

- le proprietà di sicurezza di canale o le funzionalità per cui questo verrà usato;
- quali metodi crittografici usati;
- quale è, se esiste, la controparte in IPsec.

Domanda 3

Avete notato che il vostro PC Windows ha iniziato ad essere particolarmente lento e le ventole di CPU e GPU sono sempre al massimo.Aprendo Task Manager e leggendo la lista dei processi, ne appare uno dal nome strano, crypt0jack.exe.

Spiegate cosa potrebbe essere successo e come vi comportereste per risolvere questa situazione.

Cosa è successo:

Come risolvere:

Domanda 4

Spiegare cosa sono i Common Criteria e a cosa servono. All'interno di questo contesto, spiegare cosa sono i Protection Profile e perchésono utili.

Infine, discutere cosa è il CEM e come si integra con i Common Criteria.

Common Criteria:

Protection Profile:

CEM:

ESAME GENNAIO 2024
Crocette giuste:

Domanda 1
- un IPS può permettere di velocizzare ed automatizzare la risposta alle intrusioni rilevate
- un HIDS può verificare che alcuni file non vengano modificati e analizzare quello che riportano i log dei sistemi informativi
- un SOC dovrebbe includere anche personale che si occupa dell'analisi del cybercrime per mantenere aggiornata l'analisi dei rischi

Domanda 2
- I dati relativi allo stato di salute e la razza sono considerati di categoria speciale
- Il Titolare del trattamento dei dati del Politecnico di Torino è il rettore
- Nel GDPR, il principio della privacy by design indica che bisogna usare automaticamente le protezioni più restrittive possibili -> possibile che la invalidi
- Quando una persona accetta il ruolo di DPO diventa responsabile dei danni causati dai data breach
- Un data breach è un incidente informatico che porti alla distruzione, alterazione, diffusione non autorizzata o accesso ai dati personali

Domanda 3
- Per avere una Qualified Electronic Signature la chiave pubblica deve provenire da un Qualified Certificate
- Se un documento è firmato da più persone usando firme parallele, è possibile rimuovere una firma senza che gli altri firmatari se ne accorgano
-Cambiando l'ordine di una delle firme sequenziali può far fallire la verifica di qualche firma digitale
- Il Time Stamp è, in pratica, la firma digitale di una stringa di testo o di un intero che rappresenti un valore temporale e del digest di un documento

Domanda 4
- Il Mandatory Access Control funziona confrontando le etichette (label) delle risorse e degli utenti che ne fanno richiesta e concedono l'accesso secondo modelli formali.
- L'orange book è documento redatto dal DoD il cui titotlo completo è Trusted Computer System Evaluation Criteria.
- I Common Criteria non fanno riferimento ad un processo di valutazione perché questa è trattata dalla Computer Evaluation Methodology.
- Gli standard possono permettere di stimare quando alcuni prodotti di sicurezza possono essere considerati sicuri senza fare test propri

Domanda 5
- S/MIME usa il meccanismo standard di MIME per gestire gli allegati per inserire oggetti crittografici
- HTTP-S è un'implementazione obsoleta che protegge messaggi HTTP usando strutture S/MIME
- la firma digitale di S/MIMEV4 ha sempre valore legale perché dalla versione 4 è uno standard IETF e usa crittografia asimmetrica che permette il non ripudio

Crocette sbagliate:

Domanda 1
- dal punto di vista delle intrusioni, osservare quello che avviene all'esterno della mia organizzazione non è particolarmente rilevante .

- le persone che lavorano in un SOC non dovrebbero occuparsi di vulnerability management e patch management .
- preparare le politiche di risposta agli incidenti è possibile solo se un'azienda ha un Incident Response Team .
- un SIEM (System Information Events Management) combina le funzionalità di analisi degli eventi e per la gestione di un sistema informativo
- un NIDS è uno scanner di rete che identifica vulnerabilità note
- gli honey pot sono strumenti che servono ad attirare gli attaccanti simulando il fatto che le risorse siano più facili da attaccare per aumentare il loro interesse

Domanda 2
- Il GDPR introduce il concetto di minimizzazione, che indica che i dati devono essere collezionati usando il minimo numero di strumenti e resi accessibili al minor numero di operatori
- Il DPO si occupa di riottenere i dati degli utenti quando avvengono dei data breach
-Il principio della Full Functionality del GDPR richiede che i controlli funzionino al massimo livello di sicurezza per garantire la protezione dei dati personali
- I servizi che usano dati personali devono essere pensati per proteggere questi dati durante tutte le fasi di progettazione ma non si può garantire che lo siano anche durante implementazione

Domanda 3
- Un esempio di enveloped signature è quella usata dal PKCS#7
- Un dispositivo di firma sicuro può essere ritenuto sicuro se è tamper proof e usa algoritmi ritenuti sicuri
- Forgiare una firma falsa è più facile se si usano le detached signature
- L'Advanced Electronic Signature può essere usata in tribunale
- Un Qualified Certificate certifica l'identità usando algoritmi qualificati, riconosciuti dalle entità come più efficaci

Domanda 4
- Una strength of mechanisms dichiarata alta indica che il prodotto può ritenersi molto sicuro.
- In Italia non abbiamo un Common Criteria Evalutaion Scheme, perché la certificazione CC funziona solo a livello europeo
- In una valutazione di sicurezza ai fini della standardizzazione, la correttezza della soluzione non deve tener conto del processo di sviluppo.
- Un Protection Profile è un modo per definire in maniera semplificata come verrà gestita la procedura di valutazione per security target specifici
- ITSEC non supporta la ri-valutazione di un precedente processo di standardizzazione

Domanda 5
- il formato PKCS#12 è un metodo ottimizzato per trasportare firme digitali
- il greylisting è uno strumento molto efficace per decidere se rifiutare o accettare mail da un MTA Open Relay
- i messaggi clear-signed sono visibili su qualunque strumento per la gestione delle mail e anche da web perché firmati con firma detached
- il CMS è l'evoluzione del formato PKCS#12 per la rappresentazione di dati crittografici
- il metodo STARTLS è usato per trasmettere in maniera confidenziale messagi di posta elettronica
- un server Open Relay permette di inviare mail senza restrizioni ai soli utenti interni
- il protocollo SMTP permette di autenticare gli utenti prime di inviare mail solo con metodi deboli come LOGIN, PLAIN CRAM-MD5

ESAME FEBBRAIO 2024
Crocette Giuste:

Domanda 4

- abilitando la Data Execution Prevention (DEP) rendo più difficile sfruttare i buffer overflow. [vero, la DEP è stata inventata proprio per quello, perché rendere non-executable lo stack rende impossibile usare shellcode in maniera banale]
- i ROP gadget contengono sempre istruzioni di tipo RET. [vero, per definizione un gadget termina con RET]
- la potency è una misura astratta di quanto è buona una tecnica di protezione del software,
- alcune tecniche di attestazione del codice verificano se i binari sono integri al momento dell'esecuzione o del caricamento in memoria o quando sono salvati su disco. [vero, sono diversi modi di svolgere software attestation verificando l'integrità dei binari (invece di execution correctness)]

Domanda 5

- con l'attacco Heartbleed si possono leggere dati confidenziali e altri segreti, [vero, permette di farsi inviare pezzi della memoria del processo che gestisce TLS]
- le tabelle delle connessione di un server protetto con un SYN interceptor non sono a (elevato) rischio di saturazione, [vero, l'interceptor risponde al posto del server, le tabelle del server non sono quindi troppo a rischio]
- il particolare tipo di attacco usato da Ettercap richiede che siano costantemente inviati messaggi che servono a mantenere le vittime "avvelenate". [vero, le cache si svuotano dopo un certo numero di secondi, quindi bisogna rinfrescare costantemente l'attacco, come visto ad esercitazione con il parametro arp_poison_delay]

Domanda 6

- i problemi matematici che rendono sicuri DH e ECDH sono equivalenti. [il problema dell'inverso su curve ellittiche di EDCH è computazionalmente equivalente al logaritmo discreto di DH, motivo per cui, si dice spesso che ECDH è basato su logaritmo discreto].
- il calcolo della firma digitale di un documento è un'operazione che richiede l'uso di una chiave privata sul digest del documento stesso,
- le Key Derivation Function sono progettate per essere (ragionevolmente) lente ed inefficienti nella gestione della memoria. [vero, le KDF usano le iterazioni per rallentare gli attaccanti che vogliano fare attacchi a forza bruta, le KDF moderne usano molta RAM per rendere inutilizzabili le GPU].
- in RSA, una volta calcolati n e d, non mi servono più p e q per svolgere le operazioni crittografiche.

Domanda 7

- DTLS funziona con UDP ma non con TCP. [vero, per definizione DTLS è la versione per datagram di TLS]
- se il client presenta un session-id, il server potrebbe decidere di saltare (buona parte del) la fase di Handshake e indicare di iniziare a proteggere direttamente i dati di canale a partire dai segreti negoziati in uno dei precedenti Handshake. [vero, uso la master secret del precedente Handshake (unico segreto) e gli algoritmi scelti con l'ultima ciphersuite, i random non sono segreti, ma sono parametri pubblici per la 'freshness']
- la versione più recente di TLS non usa più la compressione. [vero, dalla versione 1.3 la compressione (che era possibile, non era usata da nessuno ma portava vulnerabilità e attacchi) è stata rimossa]
- la ciphersuite TLS_DHE_DSS_WITH_AES_128_CBC_SHA indica la volontà di firmare con DSS i parametri effimeri per lo scambio di chiavi. [vero, DHE_DSS = Diffie-Hellman effimero, parametri effimeri firmati con DSS]

- OpenVPN è un protocollo che può essere usato in alternativa ad IPsec per creare Virtual Private Network.

Domanda 8
- durante la fase di risk monitoring potrei dover cambiare tutte le formule che mi permettono di stimare il rischio aziendale,
- secondo il framework RMF del NIST, la fase di framing include l'identificazione degli asset e la valutazione del loro valore,
- l'information gathering è un processo essenziale per la valutazione dell'esposizione delle aziende ai rischi informatici. [vero, l'information gathering serve per il (vulnerability/threat/risk) assessment (e non solo) e senza quelle informazioni non potrei valutare il rischio]
- conoscere il numero di sequenza che un host userà nel corso del prossimo tentativo di connessione TCP è utile agli attaccanti per fare spoofing. [vero, se voglio fare spoofing devo essere in grado di predire il prossimo sequence number che userà un host, come visto ad esercitazione, anche nmap vi dà il parametro di TCP Sequence Prediction]

ESAME FEBBRAIO 2024
CROCETTE SBAGLIATE:

Domanda 4
- nel paradigma Man-at-the-End, gli attaccanti **prendono il controllo** degli endpoint delle vittime. [falso, nel MATE gli attaccanti sono già i proprietari degli endpoint e non sono vittime, lavorano sui loro sistemi per attaccare il software]
- le protezioni del software servono a rendere impossibile violare gli asset presenti nel software. [falso, servono a ritardare gli attacchi]
- uno shellcode è un tipo di gadget; esso rilascia, una volta terminato, il controllo dell'esecuzione alla funzione chiamante e serve quando si attacca un'applicazione mediante Return Oriented Programming (ROP). [falso, shellcode non è un gadget ed il resto sono frasi che non si applicano agli shellcode]
- la white-box cryptography cifra le chiavi nel codice di un'applicazione per proteggerla da attacchi di reverse engineering. [falso, white-box crypto non cifra niente, offusca chiavi e codice]
- un disassembler ottiene in maniera deterministica la rappresentazione in codice assembly del binary machine code di un programma. [falso, i disassembler non sono deterministici, anzi talvolta non funzionano proprio e spesso le protezioni servono a non farli funzionare correttamente]

Domanda 5
- il port scanning è il metodo di information gathering con cui posso identificare con certezza i servizi in base al numero di porta su cui i servizi stessi sono in ascolto, [falso, come visto ad esercitazione, con il port scanning (-sT) so solo il numero di porta aperto, non il servizio che si scopre con la fase di service fingerprinting (-sV) e neanche con certezza]
- dato un keyed-digest calcolato come kd = H(K || M), esiste un attacco che permette di ottenere la chiave K a partire da kd. [falso, posso fare attacchi sulle collisioni ma i dati originali si perdono]
- lo Smurfing attack può essere evitato richiedendo l'autenticazione del target [falso, lo smurfing attack si evita evitando filtrando le richieste in braodcast da reti esterne (Protezione da IP spoofing), in ogni caso, il target è tipicamente esterno e non dovrebbe essere coinvolto nelle difese]
- con il FIN scanning posso distinguere filtri di livello applicativo da packet filter stateful. [falso, il FIN scanning può servire a distinguere stateful vs. stateless, non mi permette di identificare niente a livello

applicativo, del resto il TCP lavora a livello 4]
- l'attacco di Kaminski può essere evitato usando IPsec. [falso, si evita con DNSSEC]

Domanda 6
- il protocollo ESP di IPsec v1 è un esempio concreto di Authenticated Encryption with Associated Data. [falso, la v1 non supportava proprio autenticazione, quindi non può implementare authenticated encryption]
- per ottenere due messaggi che abbiano lo stesso digest usando SHA3-256 (SHA3-256(m1)=SHA3-256(m2)), servono in media gli stessi tentativi di un attacco a forza bruta contro AES-256. [falso, collisioni del secondo tipo (second pre-image attack) dimezzano il numero di bit del digest (paradosso del compleanno), quindi SHA2-256 ha 128bit di sicurezza vs. AES256 invece 256]
- SHA2 è un algoritmo sviluppato quando sono stati individuati i primi potenziali attacchi contro SHA-1.[falso, SHA2 è una famiglia di algoritmi, non un solo algoritmo]
- per fidarmi di una CRL, oltre alla verifica crittografica della firma della CA che l'ha emessa, devo aggiungere la fiducia esplicita al suo contenuto. [falso, mi fido delle CRL solo della verifica crittografica e della CA (o della root CA da cui la CA deriva), come visto anche ad esercitazione, non devo aggiungere la CRL in alcun file per farne una verifica con OpenSSL]
- con l'On-line Certificate Status Protocol posso chiedere ad un server (es. via Internet) se un determinato certificato, identificato da un serial number, è valido al momento della richiesta o in un preciso momento precedente. [falso, OCSP risponde sullo stato di un certificato solo al momento in cui arriva la richiesta]

Domanda 7
- SSH usa particolari tipi di certificati X.509 (semplificati) per trasmettere le chiavi RSA tra client e server. [falso, SSH non usa certificati, manda solo chiavi pubbliche e devo accettarle esplicitamente la prima volta che mi connetto]
- TLS usa una sliding window per evitare (parzialmente) attacchi di tipo Replay.[falso, quello è IPsec]
- la ciphersuite TLS_DH_RSA_WITH_AES_128_GCM_SHA256 indica la volontà di usare SHA256 per calcolare il MAC nel Record Protocol.[falso, usando AES_128_GCM si fa authenticated encrpytion quindi il MAC è il TAG del GCM, SHA256 serve solo come pseudo-random function]
- TLS 1.3 è perfettamente interoperabile con TLS 1.2. [falso, non sono mai interoperabili versioni diverse di protocolli, ma per TLS1.3 si poteva essere ancora più sicuri perché cambia completamente l'Handshake protocol]

Domanda 8
- il sistema semi-quantitativo, che usa valori numerici, è più efficace di quello qualitativo per categorizzare i valori delle grandezze usate nel calcolo dei rischi. [falso, sono perfettamente equivalente per la categorizzazione]
- un sistema su cui è presente una vulnerabiltà di tipo patched, nell'analisi dei rischi, deve essere considerato più a rischio rispetto a quando la vulnerabilità non era nota.[falso, una volta 'patchata' la vulnerabilità non influisce più sul rischio, come evidente dal diagramma degli stati delle vulnerabilità]
- OWASP è uno standard che serve (anche) per la valutazione del livello di sicurezza delle applicazioni web. [falso, OWASP non è uno standard, del resto non lo abbiamo visto nella parte degli standard]
- le CVSS definiscono in maniera fissa e assoluta caratteristiche e severità delle vulnerabilità notificate al MITRE. [falso, oltre al valore BASE, includono valori temporali e di contesto che permettono di far variare il valore del punteggio in modo che vulnerabilità vecchie e fuori contesto possano avere score più bassi]
- per minimizzare i rischi e ottimizzare la gestione delle patch, il NIST suggerisce di installare prima possibile le patch sui sistemi legacy perché sono di solito meno sicuri. [falso, standard first, applica le

patch prima ai sistemi che non daranno problemi, i sistemi legacy sono sempre problematici e conviene lasciarli per ultimi]

ESAME ESTIVO 2024

Crocette giuste:

Domanda 4

1) Nel paradigma Man-at-the-End, gli attaccanti **hanno** il controllo completo degli endpoint dove gli attacchi vengono preparati e realizzati
2) i ROP gadget terminano sempre con istruzioni RET
3) Le protezioni del software hanno l'obiettivo di ritardare o rendere meno vantaggiosi gli attacchi contro gli asset presenti nel software

Domanda 5

1) Un IPS può permettere di velocizzare ed automatizzare la risposta a specifiche intrusioni rilevate.
2) Un HIDS può verificare, all'interno di un host specifico, che alcuni file non vengano modificati e analizzare quello che riportano i log dei sistemi informativi.
3) Vulnerability management e patch management, secondo il NIST, sono attività che dovrebbero essere svolte da personale informatico specializzato in cybersecurity.
4) Gli honey pot non espongono asset reali agli attacchi

Domanda 6

1) In una valutazione di sicurezza ai fini della standardizzazione, la correttezza della soluzione deve tener conto anche del processo di sviluppo.
2) Il Mandatory Access Control previsto dalla classe B di TCsec usa modelli formali per stabilire quando garantire l'accesso alle risorse.
3) Anche in Italia abbiamo un Common Criteria Evaluation Scheme, perché questi organismi di valutazione funzionano su base nazionale
4) L'orange book è documento redatto dal DoD il cui titolo completo è Trusted Computer System Evaluation Criteria
5) Common Criteria non includono una metodologia di valutazione, la valutazione è trattata da un ulteriore standard (CEM).

Domanda 7

1) TLS numera i pacchetti per evitare attacchi di tipo Replay.
2) La ciphersuite TLS_DHE_RSA_WITH_AES_128_CBC_SHA indica la volontà di firmare con RSA i parametri effimeri per lo scambio di chiavi.
3) TLS 1.3 usa un Handshake Protocol diverso da quello usato fino al TLS 1.2. → 1.3 ha zero round trip time, quindi è diverso il protocollo
4) OpenVPN è un protocollo che può essere usato in alternativa ad IPsec per creare Virtual Private Network

Domanda 8

1) Per fidarmi di un certificato, oltre alla verifica crittografica della firma della CA che l'ha emesso, devo aggiungere la fiducia esplicita nei confronti della root CA
2) DH e ECDH sono basati su problemi matematici "difficili" diversi ma gli attacchi noti sono (computazionalmente) equivalenti
3) la firma digitale di un documento è il risultato di un'operazione che coinvolge l'uso di un parametro asimmetrico segreto e del digest del documento stesso

ESAME ESTIVO 2024

Crocette sbagliate:

QUESTION 4

1) Uno shellcode serve per svolgere attacchi di tipo Return Oriented Programming (ROP)
2) la Data Execution Prevention (DEP) vieta l'esecuzione di codice dai segmenti in cui ho privilegi di lettura
3) la white-box cryptography cifra le chiavi nel codice di un'applicazione per proteggerla da attacchi di reverse engineering
4) Le tecniche di attestazione del codice impediscono le modifiche al codice garantendo l'integrità
5) Un disassembler genera deterministicamente la rappresentazione in codice assembly del binary machine code di un programma

QUESTION 5

1) Dal punto di vista delle intrusioni, osservare quello che avviene all'esterno della mia organizzazione non è particolarmente rilevante.
2) Un HIDS è un tool che identifica le vulnerabilità presenti su un determinato host prima che vengano sfruttate
3) Un SIEM (Security Incident Events Management) permette di gestire in maniera automatizzata le reazioni ad attacchi e incidenti

QUESTION 6

1) Un Protection Profile dei Common Criteria definisce la procedura di valutazione per security target specifici (es. metodologia di valutazione per smart card, sistemi operativi)
2) ITSEC non supporta la ri-valutazione di un precedente processo di standardizzazione
3) La strenght of mechanism dichiarata permette di distinguere i prodotti sicuri da quelli che lo sono meno

QUESTION 7

1) L'uso della porta 443 per erogare un servizio web implica che la connessione è protetta con TLS →per convenzione ci si aspetta di trovare TLS su quella porta, ma non è detto
2) Se il client presenta un session-id valido, il server deve accettare di eseguire l'Handshake ridotto, computazionalmente molto più leggero e con meno scambi di pacchetti e idoneo a client con poca capacità computazionale (IoT) → il server non "deve" necessariamente accettare l'handshake ridotto. Inoltre, l'Handshake ridotto serve a ridurre il carico sul server, non sul client.
3) Nel caso venga scelta la ciphersuite TLS_DHE_RSA_WITH_AES_128_CBC_SHA, l'uso di algoritmi effimeri impone che SHA1 sia usato solo per generare la Master Secret (e successivamente le 4 chiavi usate per proteggere il canale) → Siccome c'è CBC, SHA serve anche per fare l'HMAC, quindi la risposta è falsa
4) SSH usa certificati X.509 semplificati per trasmettere la chiave del server

QUESTION 8

1) SHA3 è l'algoritmo scelto dopo che SHA-2 è stato deprecato dal NIST
2) Il protocollo ESP di IPsec v2 è un esempio concreto di Authenticated Encryption with Associated Data.
3) in RSA, può essere scelto qualunque esponente pubblico 'e', senza alcun effetto negativo né dal punto di vista della sicurezza né dal punto di vista computazionale
4) con l'On-line Certificate Status Protocol posso chiedere ad un server creato appositamente (es. disponibile via internet) se un determinato certificato, identificato dal suo serial number, è valido in un preciso momento del presento o passato
5) l'uso di Key Derivation Function è tipicamente sconsigliato perché sono funzioni lente ed inefficienti

nella gestione della memoria.

ESAME GENNAIO 2024
DOMANDE APERTE:

Domanda 6

Spiegare come funziona il metodo di autenticazione TOTP, indicando esplicitamente quali dati vengono usati dai client. Quali vengono inviati e quali verifiche vengono svolte dai server.
Indicare i principali tipi di attacco che si possono eseguire lato client, server e nel canale di comunicazione.

Nel modello NIST SP8000-63B, come dovrebbero essere definiti il ruolo del client e server durante l'autenticazione?

Domanda 7

Spiegare cosa è l'algoritmo RSA, quali sono i parametri pubblici e privati, quale è il problema matematico su cui si fonda la sua sicurezza.

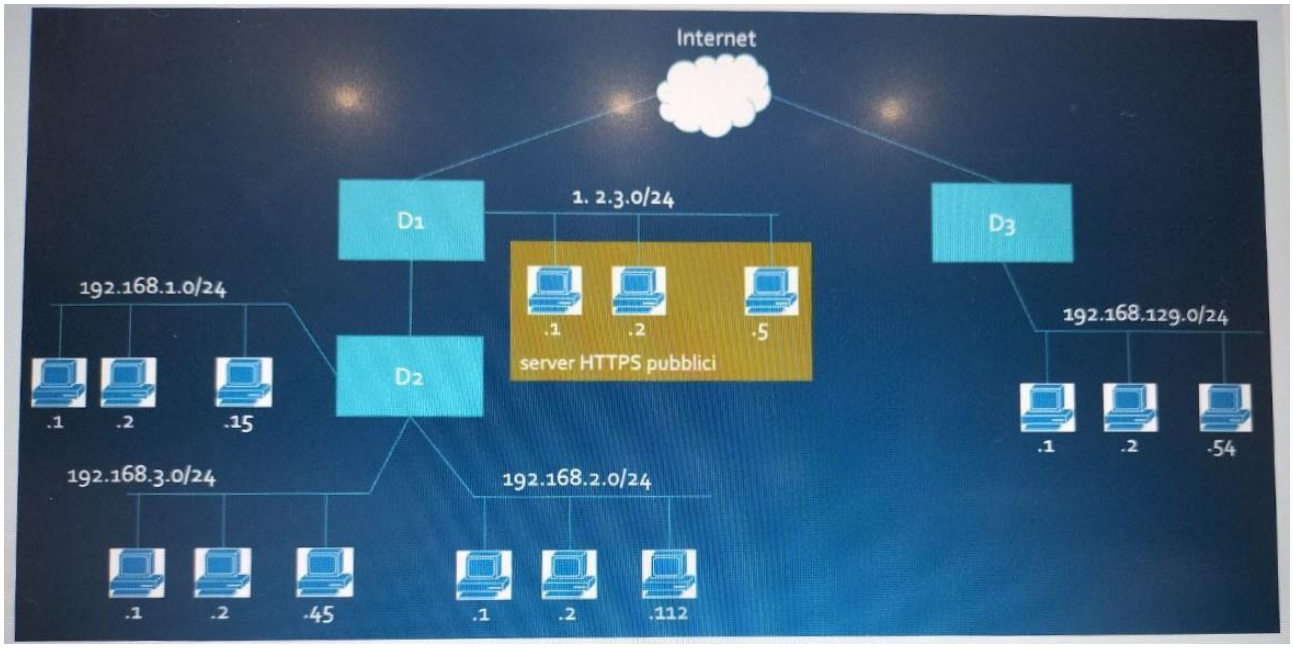
Indicare delle ottimizzazioni computazionali e discutere alcune debolezze note.

Indicare quale è il numero di bit di una chiave RSA che possa essere considerato sicuro nel 2024.

Infine, spiegare in quali fasi del TLS e di IPsec/IKE può essere usato e a quale fine

Domanda 8

Data l'architettura di rete in figura:



Ed i seguenti requisiti:

1. **Nessuna restrizione interna alle sottoreti**

2. **Nessuna rete interna (.1 / .2 / .3 /.129) deve essere raggiungibile dall'esterno**
3. **Gli host della sottorete .1 devono essere raggiungibili dalle sottoreti .2 e .3**
4. **Gli host della sottorete .2 devono essere raggiungibili dalle sottoreti .1 e .3**
5. **Gli host della sottorete .3 devono essere raggiungibili dalla sola sottorete .2**
6. **Tutti gli host interni delle sottoreti .1 .2 .3 .129 possono raggiungere internet solo dopo essersi autenticati**
7. **I server pubblici devono essere raggiungibili da Internet solo su URL fisse note a priori**
8. **Il payload dei pacchetti http che arrivano ai server HTTPs devono essere ispezionati perché non contengano tipi di file potenzialmente pericolosi**
9. **I server pubblici devono essere protetti da attacchi standard**
10. **La sottorete .2 deve comunicare in maniera sicura con la sottorete .129, il traffico deve restare confidenziale rispetto agli utenti esterni**

Indicare quali funzioni di sicurezza si dovrebbero abilitare nei dispositivi D1, D2, D3 per implementare correttamente tutti i requisiti. Notare che non è obbligatorio scegliere almeno una funzione per ognuno dei dispositivi e che in ogni dispositivo possono essere usate più funzioni.

Ogni decisione deve essere motivata e per ogni dispositivo devono essere associati i requisiti che permette di soddisfare.

Infine, scrivere le regole per implementare i requisiti 3) 4) e 5) in uno pseudo linguaggio di configurazione a scelta indicando esplicitamente la politica di default.

Questa è la riposta che ho dato all'esame e mi ha messo 6/6

Dispositivo D1
(replicare lo schema funzione+motivazione+requisiti per ogni funzione che si intende usare per tutti e tre i dispositivi)
funzione: Applicazion level Gateway a tre gambe (server pubblici in DMZ) + WAF sui server + Application level filter
motivazione: serve la DMZ come rete cuscinetto per proteggere la rete interna da eventuali attacchi ai server. Il WAF serve per ispezionare i pacchetti HTTP che arrivano ai server e il filtro per proteggere i server da attacchi standard (serve l'application layer perchè deve lavorare con gli URL dei server).
requisiti soddisfatti: 7 8 9
Dispositivo D2
funzione: Gateway per l'autenticazione + filtro statefull
motivazione: il filtro lo mettiamo per mettere le regole di comunicazione tra le 3 sottoreti (.1, .2, .3) e per verificare che esse non siano raggiungibili da internet. il gateway invece lo mettiamo per fare l'autenticazione delle sottoreti e anche per poter creare una VPN con la sottorete .129 (Basic Vpn con ESP in tunnel mode per autenticazione, integrità e confidenzialità. VPN gateway to gateway per proteggere i dati dagli utenti esterni all'azienda mentre viaggiano su internet)
requisiti soddisfatti: 2 6 10
Dispositivo D3
funzione: Gateway per l'autenticazione + filtro statefull
motivazione: come per D2 mettiamo il gateway per creare la VPN tra la sottorete .2 e la

.129 e per autenticare per raggiungere internet. il filtro invece per permettere che essa non sia raggiungibile da internet
requisiti soddisfatti: 2 6 10
Configurazione
Policy di default: white list
Regole:
requisito 3
FROM IP 192.168.2.0/24 TO IP 192.168.1.0/24 ALLOW
FROM IP 192.168.3.0/24 TO IP 192.168.2.0/24 ALLOW
requisito 4
FROM 192.168.1.0/24 TO IP 192.168.2.0/24 ALLOW
FROM 192.168.3.0/24 TO IP 192.168.2.0/24 ALLOW
requisito 5
FROM 192.168.2.0/24 TO IP 192.168.3.0/24 ALLOW

ESAME FEBBRAIO 2024
DOMANDE APERTE:

Domanda 1

Spiegare cosa sono i Common Criteria e a cosa servono. Descrivere quali sono le caratteristiche che ereditano dai precedenti standard e le peculiarità che lo rendono più flessibile e funzionale. Infine, discutere in base a cosa si deve svolgere la valutazione e quali sono gli attori in questo processo.

[iniziativa UE per standard che armonizzino i precedenti criteri (USA, EU, Canada), criteri per la valutazione di prodotti di sicurezza, servono per certificare sicurezza, evitare di dover fare assessment locali per valutare il livello di sicurezza di TOE, apertura mercati, ...]
[precedenti: valutazione generici TOE, valutazione a livelli (classi di funzionalità), rivalutazione/upgrade (volendo anche aspetti del CEM: valutazione efficacia dichiarata, valutazione correttezza)
peculiarità: Protection Profile, componenti elementari di correttezza (in classi, estensibili)]
[CEM (+azioni valutatore), Evaluation Scheme Nazionale (OSCI)]

Domanda 2

Spiegare cosa è una DMZ e in che modo può essere creata. Discutere delle implicazioni di sicurezza che portano alla scelta dell'uso di una DMZ spiegando perché la DMZ è una valida soluzione. Supponendo che il traffico da filtrare sia quello diretto verso la seguente URL:

`https://webservice.company.com/showpage.php?cmid=1293`

Commentate quali controlli potrei usare per filtrare tale traffico e fino a che punto possono essere precisi in base al livello nello stack ISO/OSI a cui operano (livello 3/4, livello applicativo, ispezione payload applicativo).

[includere almeno: sottorete a livello di sicurezza intermedio creato mediante un'architettura screened subnet normale o a tre gambe]

[includere almeno: necessità di esporre servizi ad altre reti a livello più basso e allo stesso necessità di proteggere la porzione a livello di sicurezza più alto, valida perché in caso di attacco ai servizi in DMZ la propagazione alla rete interna non è automatica ma richiede superamento di altri filtri]

[livello 3/4: faccio controlli poco precisi, può servire se IP assegnato staticamente alla URL, filtro su porta https=443

livello 7: posso filtrare su tutte le parti della URL, probabilmente non posso fare molto di più perché il traffico è cifrato a livello trasporto da TLS (ad essere precisi ma non richiesto per questo esame, posso anche filtrare in base alla parte in chiaro dell'handshake protocol)

payload: non posso fare niente perché tutto è protetto con TLS

spiegare come funziona in generale in packet filter, l7 filter, WAF, etc. non dava il massimo dei punti]

Domanda 3

Spiegare la differenza tra protezione di canale e protezione di messaggio, indicando in quali contesti è necessario utilizzare l'una o l'altra. Indicare e spiegare il funzionamento di un protocollo che implementi protezione di canale e uno che implementi protezione di messaggio. Per ognuno di essi elencare le proprietà di sicurezza che garantisce e in che modo queste vengono garantite.

[canale = endpoint fidati, protezione da MITM
messaggio= mi fido solo dell'originator, protezione aggiunta al messaggio
canale = protocolli interattivi
messaggio = store&forward]
[*canale: TLS, SSH, IPsec
es. TLS
- spiegare come funziona almeno handshake protocol per scambio di ciphersuite, segreti, autenticazione peer
- autenticazione server obbligatori, client opzionale con CRA asimmetrico con credenziali su certificati X.509
autenticazione dati e integrità: MAC o TAG di AE
confidenzialità opzionale: crittografia simmetrica, con scambio di chiavi durante handshake con DH/RSA
anti-replay: pacchetti TLS numerati
messaggio: S/MIME, DNSSEC

es. S/MIME
spiegare almeno messaggio inbustato in strutture CMS inviate come normali allegati MIME
- autenticazione originator + authc messagio e integrità: firma digitale in strutture SignedData + certificati
- confidenzialità: crittografia simmetrica in strutture Enveloped Data]

ESAME ESTIVO 2024
DOMANDE APERTE:

Domanda 1
Spiegare cosa sono il phishing (e alcune delle sue varianti) e il pretexting, indicare quali debolezze sfruttano e tramite quali canali raggiungono le vittime.
indicare un attacco famoso che ha sfruttato anche debolezze riconducibili agli esseri umani e spiegare quale debolezza ha sfruttato.

Domanda 2
Spiegare cosa sono i CRA asimmetrici, a cosa servono e come funzionano.
Fare un confronto con le TOTP indicando esplicitamente dove i CRA asimmetrici sono migliori e peggiori delle OTP

Domanda 3
Un'azienda dotata della sua rete privata aziendale vuole esporre all'esterno due servizi (HTML e posta elettronica) da due server aziendali (fisici, di proprietà dell'azienda, collocati nella rete aziendale).

Approfittando delle modifiche, hanno deciso di dividere la rete aziendale in due parti a diversi livelli di sicurezza. La parte rete della rete aziendale a livello di sicurezza più basso potrà accedere direttamente ad internet, la parte a livello di sicurezza più elevato è separata da internet dalla rete a livello di sicurezza più basso.

Progettate una soluzione che permetta di implementare una politica di autorizzazione di rete che consenta di:
- dividere la rete nei due livelli di sicurezza,
- rendere raggiungibili da internet i due servizi esposti dai server aziendali.

Indicate quali architetture e quali security control usare e come questi dovrebbero essere collegati alle varie reti e ai due server.

ESAME SETTEMBRE 2024

Solo domande:

Spiegare cosa si intende quando si parla di protezione di canale e in quali contesti viene utilizzato.

Indicare e spiegare in dettaglio il funzionamento del TLS indicando quali proprietà di sicurezza

garantisce e quali tecniche vengono usate per garantirle.

Protezione di canale:

TLS:

Proprietà e modo per garantirla:

Spiegare cosa è il Risk Management Framework del NIST e quali sono gli obiettivi di tale framework.

Elencare e descrivere le fasi e alcune delle operazioni potrebbero essere svolte in ognuna di esse.

RMF: descrizione e obiettivi :

Fasi e relativa descrizione:

Spiegare cosa sono i Common Criteria e a cosa servono. All'interno di questo contesto, spiegare cosa sono i Protection Profile e perché sono utili.

Infine discutere cosa è il CEM e come si integra con i Common Criteria.

Common Criteria:

Protection Profile:

CEM:

CROCETTE:

a. se viene effettuato un port scanning contro un server posso identificare tutte le porte aperte, quelle chiuse e quelle filtrate

b. l'attacco di Kaminski permette di forgiare richieste DNS false ma può essere evitato con DNSSEC

c. dato un keyed-digest calcolato come kd = H(k || M), è possibile ottenere la chiave K a partire da kd e da M indipendentemente da H perché esiste il length extension attack

d. lo Smurfing attack può essere evitato cifrando i pacchetti in uscita dalla rete

e. il FIN scanning permette di riconoscere i packet filter stateful da quelli stateless

f. un SYN interceptor evita che le tabelle delle connessioni dei server che scherma si saturino con attacchi di flooding

g. ettercap avvelena la cache del protocollo ARP per lanciare attacchi di tipo MitM

h. il padding calcolato con Optimal Asymmetric Encryption Padding (RSA-OAEP) evita gli attacchi contro le firme digitali calcolate con RSA

i. l'attacco Heartbleed permette di ottenere le chiavi private del server TLS attaccato

---

a. Il DPO è un soggetto indipendente che deve garantire la corretta applicazione della normativa in materia di privacy

b. Il principio della Full Functionality del GDPR richiede siano abilitati di default i controlli al massimo livello di sicurezza

c. Il GDPR introduce il concetto di minimizzazione, che indica che i dati devono essere collezionati usando il minimo numero di strumenti e resi accessibili al minor numero di operatori

d. Un data breach è un incidente informatico che porta alla distruzione, alterazione, diffusione non autorizzata o accesso ai dati personali

e. I dati relativi allo stato di salute e la razza sono considerati di categoria speciale e potrebbero richiedere protezioni aggiuntive

f. Nel GDPR, il principio della privacy by design indica che i dati devono essere protetti preventivamente e obbligatoriamente

g. In un'azienda, chiunque abbia accesso a dati relativi alla privacy devono essere noti e autorizzati dal Titolare del trattamento (es. direttamente o tramite i responsabili)

h. Il DPO è come responsabile dei dati di un'azienda, risponde dei danni in caso di data breach

i. I servizi che usano dati personali devono essere pensati per proteggere questi dati durante tutte le fasi di comunicazione (in transit) ma non è responsabilità del titolare proteggerli quando i dati sono memorizzati (at rest)

---

a. Un dispositivo di firma sicuro in grado di memorizzare in maniera tamper-proof le chiavi crittografiche (segrete) può essere usato per generare delle Qualified Signature

b. Un documento è stato firmato con quattro firme sequenziali. Se rimuovo le ultime due firme apposte, la verifica delle prime due non fallisce

c. Per verificare con successo una Qualified Electronic Signature, la chiave pubblica deve provenire da un Qualified Certificate

d. Un documento firmato con Advanced Electronic Signature può essere usato in tribunale

e. Se un documento è firmato da più persone usando firme parallele, ogni firma dipende da quelle di tutti gli altri

f. Il Time Stamp generato da una Time Stamp Authority (TSA) è la firma digitale applicata ad una valore ricevuto da un'entità esterna (es. digest) concatenato ad un valore temporale calcolato dalla TSA stessa

g. Un Qualified Certificate può essere usato per rappresentare l'identità digitale di un server ed è necessario per la generazione di Advanced Digital Signature

h. Le detached signature sono sconsigliate perché, essendo formata da due parti separate, è più semplice forgiare firme valide senza conoscere i segreti crittografici

i. PKCS#7 e CMS definiscono un formato di firma digitale di tipo enveloping

---

a. Le curve ellittiche servono a implementare algoritmi a chiave pubblica più efficienti di quelli tradizionali (campi finiti) a parità di livello di sicurezza raggiunto

b. con le CRL posso chiedere ad un server creato appositamente (es. disponibile via Internet) se un determinato certificato, identificato dal suo serial number, è valido in un preciso momento del presente o passato

c. la firma digitale di un documento è il risultato di un'operazione che coinvolge l'uso di un parametro asimmetrico segreto e del digest del documento stesso

d. l'uso di esponenti RSA pubblici come 3 e 17 rendono possibile la fattorizzazione del modulo n

e. se il server OCSP mi conferma che il certificato è valido, posso considerare validi anche documenti firmati mesi prima (sempre che tutte le altre verifiche crittografiche siano corrette nel periodo di validità del certificato)

f. SHA-2 è stato deprecato dal NIST perché esistono attacchi che ne riducono la forza sotto agli 80 bit

g. se uso il protocollo ESP di IPsec v2, posso autenticare l'header del TCP

h. l'uso delle Key Derivation Function è limitato nella pratica perché non sono abbastanza efficienti sia a livello di computazione che di uso della memoria

---

Scegli le risposte affermative:

a. gli IPS sono stati progettati per velocizzare ed automatizzare la risposta alle intrusioni o anomalie rilevate

b. un HIDS può verificare le intrusioni in uno specifico server, ad esempio monitorando che alcuni file non vengano modificati e analizzando i log dei sistemi operativi ed altri servizi attivi

c. un NIDS è uno scanner di rete che identifica le porte aperte sui sistemi e ne riconosce le vulnerabilità note

d. le politiche di risposta agli incidenti devono anche cercare di limitare gli errori umani, es. spiegando a tutto il personale come minimizzare i rischi associati al phishing (awareness)

e. un Security information and event management (SIEM) è un particolare tipo di IPS che si integra con i firewall per reagire agli eventi di sicurezza

f. per prevenire o anticipare le intrusioni, i componenti di un IDS dovrebbero monitorare i comportamenti anomali esclusivamente all'interno del mio sistema informativo

g. un SOC dovrebbe aggregare tutto il personale che si occupa di prevenire e monitorare gli attacchi contro i sistemi informativi dell'azienda ma anche rispondere agli incidenti rilevati

h. gli honey pot possono servire a sviare gli attaccanti dai veri asset aziendali

i. il vulnerability management e patch management, se applicati correttamente e adottati a livello aziendale, sono utili a prevenire gli incidenti informatici

Raccolta di esami

di

Sicurezza dei Sistemi Informatici

2011-2019

Capitolo 1
Introduzione alla sicurezza delle reti e dei sistemi informativi

1. **Parlare degli attacchi sniffing, spoofing e hijacking e descrivere le opportune misure di sicurezza.**

   Per sniffing s'intende il rilevamento dei pacchetti in transito in una rete e la loro analisi per carpirne informazioni sensibili; al fine di contrastarlo è necessaria cifratura dei pacchetti.

Lo spoofing è la falsificazione di un indirizzo IP al fine di accedere a risorse e sitemi; la contromisura è il non usare gli indirizzi per autenticazione.
L'hijacking (o Man In The Middle) è il dirottamento di una connessione da un parte di un individuo tramite la manipolazione o cancellazione di pacchetti; al fine di contrastarlo sono necessari riservatezza, autenticazione e integrità dei pacchetti

2. **Spiegare che cos'è il social engineering, fare un esempio di questo attacco, indicare le contromisure che un'azienda può adottare per difendersi.**
   Per social engeniiring si intende un tipo di attacco che non va a colpire il lato "informatico" di un'azienda/orgazizzione, ma quello umano, sfruttando le debolezze psicologiche e sociali delle persone poste in posizioni di rilievo. Un esempio molto rilevante e diffuso è il mail phishing che consiste nell'inivare email false che spingono l'utente a cliccare su link malevoli. La miglior contromisura che un'azienda può impiegare a riguardo è istruire i propri impiegati su questi rischi.

3. **Descrivere un attacco phishing e quali sono le misure per limitarlo.**
   Il mail phishing consiste nell'inviare email false che spingono l'utente a cliccare su link malevoli; alcune varianti sono il whaling (che attacca pezzi grossi) e lo spear phishing (che utilizza informazioni personali per aumentare le possibilità di successo). La miglior contromisura che un'azienda può impiegare a riguardo è istruire i propri impiegati su questi rischi.

4. **Spiegare che cosa è un attacco connection hijacking, come può essere condotto e quali contromisure si possono adottare.**
   L'hijacking (o Man In The Middle) è il dirottamento di una connessione tramite la manipolazione o cancellazione di pacchetti da un parte di un individuo che vi si immette, e può avvenire al livello fisico (tramite taglio del cavo) o logico (tramite ricezione dei pacchetti da un lato, manipolazione, e re-indirizzamento verso l'altro); al fine di contrastarlo sono necessari riservatezza, autenticazione e soprattutto integrità dei pacchetti

5. **Spiegare cosa si intende con malware food chain, chiarire perché ha questo nome ed illustrare con un esempio.**

6. **Spiegare che cosa sono gli attacchi di phishing e whaling.**
   Il mail phishing consiste nell'inviare email false che spingono l'utente a cliccare su link malevoli; il whaling è una variante che punta ad attaccare pezzi grossi di aziende o istituzioni. La miglior contromisura che un'azienda può impiegare a riguardo è istruire i propri impiegati su questi rischi.

7. **Che cosa significano le seguenti parole? Vulnerabilità, minaccia e security control? Come sono correlate?**
   Vulnerabilità: debolezza di un asset informatico

   Minaccia: evento intenzionale o accidentale che può causare la perdita di una proprietà di sicurezza sfruttando una vulnerabilità

   Security control: si usano per limitare/prevenire qualunque tipo di minaccia verso gli asset

8. **Che cosa significano le seguenti parole? Vulnerabilità, minaccia, asset ed attacco? Come sono correlate?**
   Vulnerabilità: debolezza di un asset informatico

   Minaccia: evento intenzionale o accidentale che può causare la perdita di una proprietà di sicurezza sfruttando una vulnerabilità

   Asset: l'insieme di beni, dati e persone necessarie all'erogazione di un servizio informatico

   Attacco: verificarsi di una minaccia di tipo "evento intenzionale"

9. **Spiegare cosa vuol dire DoS e fare esempi; perché è difficile da scoprire un attacco DoS; come difendersi da questi attacchi.**
   In un attacco DoS il funzionamento di un server viene impedito o limitato tramite vari metodi, come la distruzione fisica dei collegamenti o un flooding di richieste ai server al fine di sovraccaricarli; scoprire questo tipo di attacco è difficile perché spesso non è semplice identificare se si tratta effettivamente di un attacco o di un semplice malfunzionamento (senza contare il fatto che l'inaccessibilità del servizio rende difficile effettuarne una diagnostica); essendo un attacco prevalentemente di tipo brute force, non esiste un metodo semplice per proteggersi da esso se non aumentando la genera agilità e flessibilità del sistema in questione, magari aumentando il numero di server e collegamenti o migliorando l'efficienza dei software di sicurezza

10. **Cos'è Stuxnet? Come funziona e che lezioni possiamo concluderne?**
    Stuxnet è un malware che è una combinazione di worm + virus per sistemi Windows. Costituisce il prototipo di un nuovo tipo di attacco, perché è stato il primo caso noto di attacco verso i sistemi SCADA, che sono sistemi usati per controllare gli impianti industriali. Siccome i computer non erano collegati a Internet, il primo veicolo di infezione è stata probabilmente una chiavetta USB dei tecnici di manutenzione, e poi il malware si è propagato tramite i dischi di rete condivisi senza alcuna protezione.

11. **Dire cos'è la window of exposure e dove si può agire per ridurla**
    La finestra di esposizione è il periodo di tempo in cui il sistema è esposto a una minaccia di sicurezza:

    1. fase di scoperta: un attaccante sfrutta una vulnerabilità non nota:

    (a) un attaccante scopre una nuova vulnerabilità;

    (b) l'attaccante sviluppa un programma di attacco, chiamato exploit, che sfrutta tale vulnerabilità;

(c) l’attaccante inizia ad effettuare degli attacchi, facendo sì che la vulnerabilità diventi pubblica;

2. fase di pubblicazione: le persone cercano di limitare i danni:

(a) la vittima dell’attacco informa il produttore della vulnerabilità;

(b) il produttore informa tutti i suoi clienti dell’esistenza di tale problema;

(c) i clienti aggiornano gli strumenti di difesa (ad es. firme IDS), in attesa di una patch;

(d) il produttore rilascia una patch;

3. fase di protezione: i clienti applicano la contromisura:

(a) la patch è resa disponibile a tutti i clienti;

(b) solo quando tutti installano la patch, il problema può essere considerato risolto.

Per ridurla si possono fare controlli di sicurezza periodici per rilevare le vulnerabilità preventivamente , e notificare il pubblico il prima possibile in caso di attacco così da minimizzare i danni.

12. Bruce Scheiner ha scritto "security is a process, not a product" spiegare il significato di questa affermazione e fornire un esempio pratico di sua implementazione con elementi tecnici.

Comprare un singolo prodotto per fare sicurezza non è sufficiente per rendere un sistema protetto in quanto il singolo prodotto non è esente da bug, ma è necessario progettare il proprio sistema di sicurezza utilizzando più sistemi in parallelo, possibilmente di produttori diversi in modo da garantire una difesa maggiore.

L'esempio più pratico è utilizzare un firewall di un produttore e un sistema di identificazione di un secondo produttore (IDS), in questo modo in caso di bachi del primo prodotto, subentra il secondo per arginare i danni.

13. Definire i termini minaccia, vulnerabilità e security control, quindi spiegare quali relazioni intercorrono tra di loro e fornire un esempio per ciascun termine nel caso di una terna correlata

Vulnerabilità: debolezza di un asset informatico

Minaccia: evento intenzionale o accidentale che può causare la perdita di una proprietà di sicurezza sfruttando una vulnerabilità

Security control: si usano per limitare/prevenire qualunque tipo di minaccia verso gli asset

14. Spiegare brevemente la proprietà di sicurezza denominata integrità dicendo da quali attacchi protegge sia quando i dati a cui si riferisce sono memorizzati sia quando sono trasmessi.

(Risposta del professore)

Manipolazione dei dati. modifica e cancellazione.

Capitolo 2
Concetti base di sicurezza informatica

15. **Descrivere HMAC indicando i pregi e i difetti.**
HMAC è il più famoso e diffuso algoritmo per keyed-digest, ed applica una funzione di hash H, con blocco di byte B e output di L byte.

La sua forma è

HMAC=H(K' XOR opad || H(K' XOR ipad||data))

Dove:

-ipad: 0x36 ripetuto B volte

-opad: 0x5c ripetuto B volte

-K' calcolata nel seguente modo: presa una chiave K (|K|>=L)

if(|K|>B) then K'=H(K) else K'=K

if(|K'|<B) then K' 0-padded up to B bytes

Pregi e difetti:

+ pochi dati trasmessi date le piccole dimensioni del digest

+ prestazioni veloci

+ riservatezza e autenticazione con un singolo algoritmo di hash

- integrità parziale dato che possono avvenire collisioni

16. **Descrivere le proprietà di autenticazione e integrità di HMAC rispetto la firma elettronica.**
HMAC garantisce:

- integrità tramite digest
- autenticazione dei dati (ma non del mittente dato che chiunque può aver mandato quell' hash)

La firma digitale in più fornisce autenticazione del mittente perché l'hash viene cifrato usando la sua chiave privata, ed esiste un certificato X.509 che ne certifica l'identità

17. **What is integrity? Mention some possible attacks related to it?**
Si definisce integrità la proprietà che indica se un dato ha subito manipolazioni; alcuni possibili attacchi all'integrità di un messagio o pacchetto sono quelli di tipo MITM, i quali possono modificare i pacchetti nella connessione

18. **Calcolare quanti dati devono essere salvati su disco per eseguire la decifratura e l'autenticazione di un file grande 1kB con digest SHA-1 e chiave RSA 1024 bit.**
Supponendo cifratura AES-128-CTS (quindi no padding): si hanno:

-128B (1024 bit) chiave simmetrica AES cifrata con la Kpri del mittente

-128B (1024 bit) Kpub del mittente (in caso non si abbia HSM)

-1kb per il plaintext

-20B (160 bit) per il digest SHA-1

In totale 1300 senza HSM, 1172 con HSM (che mantiene la chiave nella propria memoria)

19. **Cosa significano i seguenti acronimi: DSA, RC-4, RIPEMD?**
-DSA: è un algoritmo di crittografia asimmetrica che fa esponenziale da un lato e logaritmo dall'altro; si usa solo per firma digitale (quindi niente cifratura), dato che la funzione che utilizza se applicata su plaintext causerebbe perdita dei dati

-RC-4: algoritmo di cifratura simmetrica di tipo stream, ovvero che si applica ad un stream di bit continuo: il funzionamento di base è che sorgente e destinazione concordino un seme usato per cifrare e decifrare

-RIPEMD: algoritmo di hash crittografico; considerato ottimo ma scarsamente utilizzato

20. **Dare una breve descrizione di: RC4, RSA, RIPEMD.**
-RSA: è un algoritmo di crittografia asimmetrica a blocchi che genera le sue chiavi usando due esponenti; la scelta di tali esponenti è fondamentale per la qualità del risultato finale (in particolare, il prodotto dei due esponenti deve essere inferiore alle dimensioni del blocco da cifrare)

-RC-4: algoritmo di cifratura simmetrica di tipo stream, ovvero che si applica ad un stream di bit continuo: il funzionamento di base è che sorgente e destinazione concordino un seme usato per cifrare e decifrare

-RIPEMD: algoritmo di hash crittografico; considerato ottimo ma scarsamente utilizzato

21. **RC-4 stream**
algoritmo di cifratura simmetrica di tipo stream, ovvero che si applica ad un stream di bit continuo: il funzionamento di base è che sorgente e destinazione concordino un seme usato per cifrare e decifrare

22. **Differenza algoritmi stream e a blocchi**
Gli algoritmi cifrano il file principale dividendolo in blocchi e cifrando ciascuno in maniera più o meno separata con la chiave in base all'algoritmo scelto (ad esempio ECB cifra ciascun blocco separatamente, mentre CBC cifra ciascuno blocco n dopo il primo facendone XOR con il risultato del passo n-1); gli algoritmi stream si applicano ad un stream di bit continuo: il funzionamento di base è che sorgente e destinazione concordino un seme usato per cifrare e decifrare (alcuni esempi sono RC4, Salsa20 e ChaCha20)

Gli algoritmi stream sono tendenzialmente più veloci di quelli a blocchi dato che effettuano un semplice XOR, ma richiedono costante sincronia tra mittente e destinatario (ciò non li rende buoni per le trasmissioni internet); di confronto, gli algoritmi a blocchi sono nettamente più lenti date le varie operazioni che è necessario effettuare per combaciare i dati alle dimensioni dei blocchi (come il padding), ma si ma si prestano molto bene alla trasmissione dei pacchetti internet

23. **Perché gli algoritmi di stream sono più veloci?**

Gli algoritmi stream sono tendenzialmente più veloci di quelli a blocchi dato che effettuano un semplice XOR, ma richiedono costante sincronia tra mittente e destinatario (ciò non li rende buoni per le trasmissioni internet), nonché il fatto che gli algoritmi a blocchi sono nettamente più lenti date le varie operazioni che è necessario effettuare per far combaciare i dati alle dimensioni dei blocchi (come il padding)

24. **Un'azienda deve scambiare con un'altra dei file ma possono utilizzare soltanto una chiave di 12 caratteri max; indicare come deve essere implementato il sistema (NOTA: volevano nella soluzione che si parlasse anche di kdf)**
Creo una chiave con K=pbkdf(pwd, sale, itc), e utilizzo IPsec in tunnel mode sui gateway aziendali per avere integrità dei dati e autenticazione del mittente; ipotizzando che i file da scambiare siano particolarmente sensibili, si consiglia l'uso della cyphersuite VPN-B per avere anche riservatezza sui dati

25. **Un messaggio di 28 byte viene cifrato con DES-CBC: quanti byte verranno inviati in totale?**
DES ha blocchi da 64bit (8 byte), quindi 28<32/8=4 blocchi da 8 byte più un blocco delle stesse dimensioni per l'IV, in totale (4+1)*8=40byte

26. **Se devo cifrare in modalità DES-CBC un file da 84 byte, quanti byte trasmetterò in rete?**
3DES ha blocchi da 64bit (8 byte), quindi 84<88/8=11 blocchi da 8 byte più un blocco delle stesse dimensioni per l'IV, in totale (11+1)*8=96 byte

27. **Avendo un file da 1500 byte, se lo cifro con 3DES-CBC quanto sarà grande il file finale?**
3DES ha blocchi da 64bit (8 byte), quindi 1500#8=4 byte nell'ultimo blocco che necessitano di 8-4=4 byte di padding per riempirlo, quindi in totale il file avrà dimensione 1500+4=1504byte

28. **CBC vs CTR: come funzionano, vantaggi e svantaggi**
CBC è un algoritmo di cifratura a blocchi che cifra ciascuno blocco n dopo il primo facendone XOR con il risultato del passo n-1 (per il primo passo si usa invece un vettore di inizializzazione IV, che in trasmissione può essere mandato nascosto o anche in chiaro)

    Vantaggi e svantaggi:

    + No attacchi di swapping

    + No attacchi known plain text

    - Propagazione degli errori in caso di perdita e errore in trasmissione di un blocco

    - No parallelizzazione CPU

CTR è un metodo per trasmettere file con dimensioni inferiori a quelle di un blocco: si dividono i dati in gruppi, e si mischia ciascun gruppo con un nonce+contatore che viene incrementato ad ogni gruppo (il nonce deve essere identico a destinazione)

Lo svantaggio principale è che la cancellazione di un blocco causa la desincronizzazione del contatore

29. **Due utenti desiderano scambiarsi via rete una serie di documenti informato ASCII (.TXT). Suggerire quali operazioni è opportuno svolgere su questi documenti prima di trasmetterli per resistere ad attacchi sulla rete (insicura). Si tenga presente che i documenti non contengono info riservate. Nota: non si usino protocolli o formati dati complessi. Si esprima la soluzione tramite formula (usando termini appropriati, come aes(k,d) piuttosto che enc(k,d))**
n=nonce+counter

k=DH

digest=hmac_sha256(k, P||n)

c=P||digest||n

30. **Utente A vuole mandare un messaggio segreto e autenticato agli utenti B e C, tutti e tre hanno un paio di chiavi RSA a testa. Descrivere il formato del data block per inviare il messaggio con le richieste proprietà di sicurezza.**
Bisogna cifrare con le chiavi pubbliche di B e C e firmare con la propria privata e distribuire la chiave pubblica di A, quindi:
-C riceve: AES_128(Kpub;c , M)||HMAC-SHA256(AES_128(Kpub;c , M), Kpri;a)||Kpub;a

-B riceve: AES_128(Kpub;b , M)||HMAC-SHA256(AES_128(Kpub;b , M), Kpri;a)||Kpub;a

31. **Parlare del meccanismo del keyed digest (cos'è, quando e come si usa, vantaggi e svantaggi).**
In un soluzione di questo tipo, si invia un digest calcolato non solo sui dati, ma anche su un segreto (chiave) e solo chi conosce K puo calcolare il digest sui dati ricevuti e confrontarli con il digest trasmesso. Tale soluzione e molto utilizzata in ambito di rete.

Proprietà di sicurezza:

+ integrità: se i dati in chiaro vengono modificati, il keyed-digest kd*R* calcolato sui dati ricevuti sarà diverso dal keyed-digest kd*F* ricevuto;

+ autenticazione: solo chi conosce la chiave segreta può aver generato un keyed-digest corrispondente ai dati;

− riservatezza: i dati sono inviati in chiaro;

− non ripudio: non è possibile stabilire quale peer ha generato i dati.

Vantaggi e svantaggi:

+ quantità di dati trasmessi: il keyed-digest è molto piccolo rispetto ai dati;

+ tempo di calcolo: gli algoritmi di hash sono veloci da eseguire;

+ implementazione: un singolo algoritmo di hash è sufficiente per garantire sia riservatezza sia autenticazione.

- integrità parziale: possono avvenire delle collisioni, poiché è teoricamente

impossibile individuare tutte le possibili modifiche

32. Parlare del keyed-digest e la firma digitale, quali sono le proprietà che offrono, vantaggi e svantaggi?

Keyed-digest: si invia un digest calcolato non solo sui dati, ma anche su un segreto (chiave) e solo chi conosce K puo calcolare il digest sui dati ricevuti e confrontarli con il digest trasmesso. Tale soluzione e molto utilizzata in ambito di rete.

Proprietà di sicurezza:

+ integrità: se i dati in chiaro vengono modificati, il keyed-digest kd*R* calcolato sui dati ricevuti sarà diverso dal keyed-digest kd*F* ricevuto;

+ autenticazione: solo chi conosce la chiave segreta può aver generato un keyed-digest corrispondente ai dati;

− riservatezza: i dati sono inviati in chiaro;

− non ripudio: non è possibile stabilire quale peer ha generato i dati.

Vantaggi e svantaggi:

+ quantità di dati trasmessi: il keyed-digest è molto piccolo rispetto ai dati;

+ tempo di calcolo: gli algoritmi di hash sono veloci da eseguire;

+ implementazione: un singolo algoritmo di hash è sufficiente per garantire sia riservatezza sia autenticazione.

- integrità parziale: possono avvenire delle collisioni, poiché è teoricamente impossibile individuare tutte le possibili modifiche

Firma digitale: viene calcolato un digest con un algoritmo crittografico e associato con un oggetto di dati in modo tale che qualsiasi destinatario dei dati può usare la firma per verificare l'origine e l'integrità dei dati

Proprietà di sicurezza:

+ integrità: se i dati in chiaro vengono modificati, il digest md*R* calcolato sui dati ricevuti sarà diverso dal digest md*F* ricevuto e decriptato;

+ autenticazione: solo chi conosce la chiave privata può aver generato una firma digitale corrispondente ai dati;

− riservatezza: i dati sono inviati in chiaro;

+ non ripudio: il mittente non può negare di aver firmato i dati, a patto che la sua chiave pubblica sia fornita da un certificato a chiave pubblica.

Vantaggi e svantaggi:

+ pochi dati aggiuntivi

- inapplicabile ad un flusso di dati in real time

33. **Un'azienda vuole fare firma digitale su tutti i suoi documenti e conservare sia i documenti sia le firme in modo da poterli verificare anche in futuro. Che cosa usare? Che cosa deve memorizzare insieme alla firma?**
Una enveloping CMS, contenente le varie firme associate a un dato documento e i corrispettivi certificati, più aggiornamento costante delle CRL associate alle varie firme possedute per verificarne la validità

34. **Quali proprietà di sicurezza offre la firma digitale, come si realizza, quali parti della firma offrono quelle proprietà di sicurezza.**
Nella firma digitale viene calcolato un digest con un algoritmo crittografico e associato con un oggetto di dati in modo tale che qualsiasi destinatario dei dati può usare la firma per verificare l'origine e l'integrità dei dati

Proprietà di sicurezza:

+ integrità: se i dati in chiaro vengono modificati, il digest md*R* calcolato sui dati ricevuti sarà diverso dal digest md*F* ricevuto e decriptato;

+ autenticazione: solo chi conosce la chiave privata può aver generato una firma digitale corrispondente ai dati;

− riservatezza: i dati sono inviati in chiaro;

+ non ripudio: il mittente non può negare di aver firmato i dati, a patto che la sua chiave pubblica sia fornita da un certificato a chiave pubblica.

Vantaggi e svantaggi:

+ pochi dati aggiuntivi

- inapplicabile ad un flusso di dati in real time

35. **Perché l'algoritmo SHA-1 è deprecato? Suggerire una possibile e valida alternativa e motivare perché questa sia migliore di SHA-1.**
SHA-1 era un algoritmo complessivamente buono, ma anche estremamente attaccato. Difatti, un gruppo di ricercatori cinesi e riuscito a trovare collisioni con soli 2^69

calcoli. È stato successivamente diffuso SHA-2. Come rimedio veloce dopo l'attacco a SHA-1, la famiglia SHA-2 e stata creata allungando il digest, in maniera simile a quanto avvenuto fra DES e 3DES.

36. Ordinare dal più veloce al più lento i seguenti algoritmi: SHA, AES_ECB, AES_CBC, RC4

SHA, RC4, AES_ECB, AES_CBC

37. Dati i seguenti algoritmi di cifratura, ordinarli dal più lento al più veloce: AES, DES, RC4, 3DES.

3DES, DES, AES, RC4

38. Descrivi la crittografia a curve ellittiche.

La crittografia a curve ellittiche (ECC) utilizza l'aritmetica delle curve ellittiche bidimensionali, invece dell'aritmetica modulare monodimensionale.

Dal punto di vista concettuale, invece di usare numeri (che sono punti su una retta) si prende lo spazio cartesiano, e i valori che sono validi sono solo i punti che soddisfano l'equazione di una curva ellittica.

Il problema del logaritmo discreto su una curva è più complesso da risolvere per i cattivi rispetto al problema del logaritmo discreto nell'aritmetica modulare, quindi le chiavi per l'ECC possono essere più corte (circa 1/10) per un livello di sicurezza comparabile, riducendo i requisiti di memorizzazione sui dispositivi embedded.

Alcuni esempi d'uso sono l'ECDSA (Elliptic Curve DSA) per firma digitale, e il ECDH (Elliptic Curve DH) per il key agreement.

39. Dire i due principali vantaggi degli algoritmi basati su ECC

Il problema del logaritmo discreto su una curva è più complesso da risolvere per i cattivi rispetto al problema del logaritmo discreto nell'aritmetica modulare, quindi:

1) Le chiavi per l'ECC possono essere più corte (circa 1/10) per un livello di sicurezza comparabile
2) Per i buoni tutti gli algoritmi richiedono solo due operazioni elementari che danno come risultato dei punti

40. Descrivi l'algoritmo di keyed-digest CBC-MAC.

Il MAC è costituito dall'ultimo blocco di testo cifrato risultante dall'applicazione di un algoritmo di crittografia simmetrica a blocchi in modalità CBC, con vettore di inizializzazione IV nullo (la riservatezza non è necessaria): tutti i blocchi di testo cifrato vengono buttati via eccetto l'ultimo, che viene preso come MAC) il destinatario potrà criptare i dati ricevuti con lo stesso algoritmo di crittografia e confrontare l'ultimo blocco di testo cifrato risultante con il blocco di testo cifrato ricevuto.

41. Uno dei primi metodi per criptare i dati?

Electronic Code Book (ECB), che consisteva in:

1. suddividere il testo in chiaro da criptare in blocchi base di dimensione fissa;

2. applicare l'algoritmo di criptazione su ciascun blocco *i*-esimo, indipendentemente dagli altri blocchi:

$$Ci = \text{enc}\ (K, Pi)$$

3. concatenare i blocchi risultanti per produrre il testo cifrato.

La decriptazione avviene invertendo la sequenza di operazioni:

$$Pi = \text{enc}{-}1\ (K, Ci)$$

Ormai obsoleto dato che era soggetto a vari tipi di attacco, tra cui principalmente swapping e known-plain text

42. Su sistemi embedded spesso si preferisce ECDSA rispetto a RSA: perché?

Perché le chiavi per l'ECC possono essere più corte (circa 1/10) per un livello di sicurezza comparabile, riducendo i requisiti di memorizzazione sui dispositivi embedded.

43. Qual è il principale vantaggio della modalità di cifratura CTR?

La capacità di parallelizzare la CPU nel calcolo, in quanto un qualsiasi gruppo può essere criptato senza dover criptare i gruppi precedenti (accesso casuale).

44. Indicare quale attacco all'integrità è possibile se dei dati D vengono protetti con un MAC calcolato nel seguente modo (k è la chiave e h è la funzione di hash): MAC =h (k || D).

Se si concatena un altro blocco in coda il digest sarà diverso e il buono non se ne accorgerà, quindi verrà cambiato il digest in qualche modo pur senza conoscere la chiave condivisa.

45. Vantaggi e svantaggi di cifratura fatta con enc(enc(p, k1), k2) con k1 e k2 chiavi diverse ma di lunghezza uguale

In genere non si utilizza mai un'applicazione doppia di algoritmi di cifratura, motivo per il quale viene evitata, dato che non aumenterebbe il livello di sicurezza in maniera significativa. Inoltre, l'applicazione doppia di algoritmi di cifratura e soggetta ad un attacco di tipo known-plaintext, chiamato meet-in-the-middle, che permette di decifrare i dati con al piu 2N+1 tentativi (per chiavi da N bit). In breve, raddoppia il tempo di calcolo ma la lunghezza della chiave aumenta di un solo bit.

46. Descrivere la tecnica crittografica ECB identificandone vantaggi e svantaggi.

L'Electronic Code Book (ECB), che consiste in:

1. suddividere il testo in chiaro da criptare in blocchi base di dimensione fissa;

2. applicare l'algoritmo di criptazione su ciascun blocco *i*-esimo, indipendentemente dagli altri blocchi:

$$Ci = \text{enc}\ (K, Pi)$$

3. concatenare i blocchi risultanti per produrre il testo cifrato.

La decriptazione avviene invertendo la sequenza di operazioni:

$$Pi = \text{enc}{-}1\ (K,Ci)$$

Vantaggi

• no propagazione degli errori: un errore nella trasmissione provoca un errore nella decriptazione di un solo blocco senza propagarsi agli altri blocchi;

• parallelizzazione della CPU: è possibile lavorare su più blocchi allo stesso tempo.

Svantaggi

• attacchi di swapping: la criptazione non dipende dalla posizione del blocco) è possibile scambiare due blocchi, o spostare un blocco, qualunque senza che ciò venga scoperto;

• attacchi known-plaintext: blocchi identici sono criptati allo stesso modo) un attaccante può costruire un database contenente gli output delle criptazioni con tutte le possibili chiavi di un blocco ricorrente (ad es. intestazione di un documento di Word), per poi trovare la chiave confrontando ogni blocco del testo cifrato alla ricerca del blocco ricorrente (pattern).

47. Quale delle seguenti tecniche – firma digitale, cifratura simmetrica, keyed-digest – sarebbe da preferire per proteggere l'integrità di un flusso di pacchetti a 1 Gbps? Giustificare la scelta.

Keyed-digest perchè è la tecnica più veloce, hash veloce e usa una sola operazione. La firma non si può fare su un flusso di dati. La cifratura è lenta

48. Quale tecnica è meglio usare per proteggere dati trasmessi in rete da attacchi di tipo replay? Cifratura simmetrica, cifratura asimmetrica, keyed-digest, altro? Giustificare.

Si parla di soli attacchi replay, quindi basta garantire Integrità con un keyed digest basato su chiave simmetrica (concordata a inizio sessione o meglio generata pseudo-randomicamente da un segreto condiviso):

d = kd(K||n||M||K)
invio M||n||d

Nel KD pongo K agli estremi in modo da evitare prefix e postfix attack

49. Due utenti devono scambiarsi dei file di testo formato ASCII (txt) non riservati. Come fanno a garantire che non vengano modificati durante il transito? Spiegare quali funzioni di sicurezza usare e enunciare la formula che produce il documento X trasmesso rispetto al documento originale. Si usino nomi significativi (es. aes(K,D) rispetto a enc(K,D).

k=DH, genero chiave
d=HMAC_SHA256(k, M), creo digest messaggio per integritàe autenticazione
X=M||d, invio messaggio + digest

50. **Si deve trasmettere cifrata una password da 12 caratteri con 2 byte di sale con AES. Cosa si usa tra ECB, CBC e CBF?**
CBF (ma non lo abbiamo studiato, ignorare)

51. **Dovendo cifrare con AES una password da 12 caratteri con 2 byte di sale è meglio usare ECB, CBC o CTR?**
Aes ha un blocco da 128 bit, 12 caratteri ascii quindi da 8 bit ciascuno sono 96 bit più 16 bit di sale sono 112 bit, quindi inferiore al blocco, il che mi porterebbe a usare CTR

52. **Firma digitale con digest SHA256, chiave privata RSA-2048 su un file da 10MB. Qual'è la dimensione della firma?**
Poiché viene utilizzato una chiave privata RSA-2048 la dimensione della firma sarà 2048bit

53. **Come possono inviarsi un file due tizi che condividono una password**
Tramite algoritmi a chiave simmetrica, usando la password come chiave

54. **Si deve firmare un documento da 10 MB con digest SHA-1 e chiave RSA. Quanto è grande esattamente la firma del documento?**
Dipende dalle dimensioni della chiave RSA. Ipotizzando che sia di 2048 bit, la firma sarà lunga anch'essa 2048 bit

55. **Quali algoritmi si possono usare per scambiare chiavi segrete?**
Quelli a chiave asimmetrica (come RSA), dato che non si deve inviare nessun segreto per farli funzionare

56. **Quali algoritmi si possono usare per comunicare una certa chiave segreta a una controparte?**
Quelli a chiave asimmetrica (come RSA), dato che non si deve inviare nessun segreto per farli funzionare

57. **Hash per calcolare la password partendo da un seme.**

58. **Per quale applicazione è stato inventato il CTS?**
La tecnica del ciphertext stealing (CTS) permette di usare gli algoritmi a blocchi in modalità ECB o CBC senza ricorrere al padding.

59. **Spiegare cos'è la modalità operativa CTS qual è l'idea principale su cui si basa la sua implementazione e perchè sta assumendo sempre più rilevanza**
Il CTS e una tecnica che permette di utilizzare algoritmi a blocchi senza il padding. All'ultimo blocco vengono aggiunti dei byte del blocco precedente, rimuovendoli dal penultimo blocco.Per evitare il padding standard, si utilizza come padding stesso una parte del ciphertext gia cifrato. Cio, per file di grandi dimensioni, non è drammatico, in quanto riguarda solamente gli ultimi due blocchi.. E' utile quando non si puo/vuole aumentare la dimensione dei dati dopo la cifratura.

60. **Perché non si usa 2DES e si preferisce 3DES?**

In genere non si utilizza mai un'applicazione doppia di algoritmi di cifratura come il 2DES, motivo per il quale viene evitata, dato che non aumenterebbe il livello di sicurezza in maniera significativa. Inoltre, l'applicazione doppia di algoritmi di cifratura e soggetta ad un attacco di tipo known-plaintext, chiamato meet-in-the-middle, che permette di decifrare i dati con al piu 2N+1 tentativi (per chiavi da N bit). In breve, raddoppia il tempo di calcolo ma la lunghezza della chiave aumenta di un solo bit. Il 3DES non ha invece di questi problemi.

61. **Calcolare quanti dati devono essere salvati su disco per eseguire la decifratura e l'autenticazione di un file grande 1 kB con digest SHA-1 e chiave RSA 1024 bit. 1Kb_file + 1Kb_PublicKey + 160bit_storedDigest = 2208 bit: per decifrare il file abbiamo bisogno di esso e della chiave pubblica. Per autenticarlo servono il digest e la chiave pubblica per verificarlo**

62. **Quali algoritmi base (non strutture dati complesse) si possono utilizzare per garantire riservatezza di un file situato su un server di cui non ci si fida?**

63. **Spiegare il termine security through obscurity. Spiegare perché alcuni dicono sia buono ed altri no.**
Tentare di mantenere o aumentare la sicurezza di un sistema tenendo segrete la progettazione o la costruzione di un meccanismo di sicurezza. Alcuni non lo ritengono un buon metodo di difesa perché in un sistema open è più facile trovare ed annunciare eventuali vulnerabilità.

64. **Spiegare la authenticated encryption.**
Gli algoritmi authenticated encryption (AE) combinano le operazioni di crittografia e

keyed-digest in una singola operazione:

+ riservatezza e autenticazione (e integrità) con un solo algoritmo e una sola chiave;

+ maggiore velocità;

+ minor rischio di errori di implementazione.

L'AE sta diventando una necessità sempre più crescente a livello applicativo (ad es. per i messaggi di posta elettronica).

Gli algoritmi AE possono essere:

• AEAD o no: alcuni dati autenticati possono essere lasciati non criptati;

• single-pass o double-pass: un algoritmo double-pass ha bisogno di memorizzare i risultati della prima passata per ulteriori calcoli) è almeno due volte più lento di un algoritmo one-pass se implementato in software;

• on-line o off-line: i dati possono essere presi così come arrivano dal filo o devono essere prima salvati tutti.

I normali schemi di criptazione sono soggetti ad attacchi chosen-ciphertext (oracle) se usati on-line:

1. l'attaccante modifica un testo cifrato;

2. l'attaccante osserva se il ricevente segnala errore o meno.

65. CBC e CTR mode: spiegare, vantaggi e svantaggi.

CBC è un algoritmo di cifratura a blocchi che cifra ciascuno blocco n dopo il primo facendone XOR con il risultato del passo n-1 (per il primo passo si usa invece un vettore di inizializzazione IV, che in trasmissione può essere mandato nascosto o anche in chiaro)

Vantaggi e svantaggi:

+ No attacchi di swapping

+ No attacchi known plain text

- Propagazione degli errori in caso di perdita e errore in trasmissione di un blocco

- No parallelizzazione CPU

CTR è un metodo per trasmettere file con dimensioni inferiori a quelle di un blocco: si dividono i dati in gruppi, e si mischia ciascun gruppo con un nonce+contatore che viene incrementato ad ogni gruppo (il nonce deve essere identico a destinazione)

Lo svantaggio principale è che la cancellazione di un blocco causa la desincronizzazione del contatore.

66. Qualcuno ti ha inviato un file firmato digitalmente con RSA e SHA-. . . , insieme al certificato del firmatario e al certificato della sua CA. Descrivere come validare la firma, identificare le informazioni richieste ed ottenere l'accesso ad esse.

67. Descrivere DH, i suoi problemi e le soluzioni ad essi.

Diffie-Hellman (DH) è stato il primo algoritmo ad usare il concetto di pubblicare qualche cosa (i numeri p e g), e quindi in questo senso spesso è definito come il primo algoritmo a chiave pubblica inventato.

DH non è un metodo per distribuire la chiave, ma per concordare la chiave:

1. il mittente X e il ricevente X scelgono o concordano due numeri interi pubblici, un generatore g (tipicamente 2, 3 o 5) e un numero primo p (grande), tali che $p > g > 1$

2. X sceglie arbitrariamente un numero intero $x > 0$ (grande), e calcola $A = gx \bmod p$

3. Y sceglie arbitrariamente un numero intero $y > 0$ (grande), e calcola $B = gy \bmod p$

4. X invia (pubblica) il valore calcolato A a Y ;

5. Y invia (pubblica) il valore calcolato B a X;

6. X riceve B, e calcola $KA = Bx \bmod p$

7. Y riceve A, e calcola $KB = Ay \bmod p$

8. per la proprietà delle potenze, i valori KA e KB, calcolati indipendentemente da X e Y , sono uguali e costituiscono la chiave segreta KAB:

$$KA = (gy)x \bmod p,$$

$$KB = (gx)y \bmod p$$

$$\rightarrow KA = KB = gxy \bmod p = KAB$$

Il problema principale di questo algoritmo sta nella fase di key agreement: nel caso in cui però l'attaccante sia in grado di manipolare i dati in transito, può allora sniffare il traffico tra le parti manipolarli. Questa operazione risulta del tutto trasparente al mittente e al ricevente: essi non hanno modo di sapere che al di là del canale protetto non c'è la controparte ma c'è l'attaccante, le chiavi che credono di aver concordato sono diverse, e i dati sono stati manipolati. È quindi necessario proteggere le chiavi scambiate tramite un processo di pre-autenticazione usando:

• certificati per le chiavi DH;

• protocolli autenticati varianti del DH

68. RSA, RC4, SHA-1, . . . : qual è l'intruso e perché?
sha1 perché è un algoritmo di digest mentre gli altri di cifratura

69. Descrivere step-up (gated) cryptography.

70. Spiegare brevemente la tipologia di cifratura simmetrica e quella asimmetrica, indicando i vantaggi e svantaggi di ciascuna tipologia.

(Risposta del professore)

1) simmetrica: C = enc (K,P), P = dec (K,C);
vantaggi: veloce, key generation semplice
svantaggi: key distribution

2) asimmetrica:
svantaggi: lenta, key generation, key distribution

Capitolo 3
Sistemi di autenticazione

71. Sistemi di autenticazione a sfida simmetrici, vantaggi e svantaggi.

Un sistema a sfida è un processo di autenticazione che verifica un'identità richiedendo che siano fornite le informazioni di autenticazione corrette in risposta a una sfida; la versione simmetrica richiede che la risposta alla sfida sia calcolata con la chiave comune condivisa col server

Pro e contro:
+ no sniffing
+ no replay (la sfida contiene un nonce)
- lato client, l'utente deve avere un funzione di hash per calcolare la risposta (non sempre possibile)
- il server non può memorizzare l'hash delle password, ma deve conoscerle in chiaro al fine di calcolare l'hash della soluzione
- la sfida passa in chiaro

72. Autenticazione simmetrica, cos'è, come funziona, vantaggi, punti deboli.

Un sistema a sfida è un processo di autenticazione che verifica un'identità richiedendo che siano fornite le informazioni di autenticazione corrette in risposta a una sfida; la versione simmetrica richiede che la risposta alla sfida sia calcolata con la chiave comune condivisa col server.

Procedura di autenticazione

1. identificazione: il client invia il proprio UID;

2. richiesta di una prova: il server genera un numero nonce e casuale n e lo invia come **sfida**;

3. prova: il client calcola il keyed-digest sulla sfida ricevuta, usando il segreto condiviso k come chiave

$$d = H(k, n)$$

e trasmette il keyed-digest d calcolato come soluzione alla sfida;

4. controllo: il server esegue lo stesso calcolo della soluzione usando la sfida generata e il segreto condiviso, e confronta la prova d ricevuta con la soluzione calcolata:

$$\text{if } (d = H(k, n)) \text{ then OK else ALARM}$$

Pro e contro:
+ no sniffing
+ no replay (la sfida contiene un nonce)
- lato client, l'utente deve avere un funzione di hash per calcolare la risposta (non sempre possibile)
- il server non può memorizzare l'hash delle password, ma deve conoscerle in chiaro al fine di calcolare l'hash della soluzione

- la sfida passa in chiaro

73. Kerberos è detto essere un sistema di autenticazione TTP. Spiegare perché è classificato in questo modo e quale rischi corrono i client ed i server applicativi se il terzo non si comporta correttamente.

TTP sta per Third Thrusted Party, e kerberos ha questa definizione perché il suo sistema di autorizzazione utilizza anche un server di rilascio di ticket intermedio tra pretender e verifier.

74. Kerberos: spiegare cosa significa trusted third party.

TTP sta per Third Thrusted Party, e kerberos ha questa definizione perché il suo sistema di autorizzazione utilizza anche un server di rilascio di ticket intermedio tra pretender e verifier.

75. Spiegare cos'è l'attacco dizionario: sotto quali ipotesi può essere condotto e quali contromisure adottare.

Un attacco a dizionario è un tipo di attacco a forza bruta con lo scopo di scoprire una password conoscendone l'hash (= digest): viene usata una lista, detta dizionario, che contiene solo le password più probabili, ovvero quelle che gli esseri umani scelgono più di frequente perché facili da ricordare.

Può essere condotto se l'attaccante ha accesso alle informazioni nel server:

- ha il database del server contenente gli hash corrispondenti alle password degli utenti

- conosce l'algoritmo di hash usato per calcolare gli hash

Utilizzando del "sale" (ovvero una stringa randomica aggiunta alle è password prima dell'hashing) si annulla completamente il rischio di questo attacco

76. Confrontare le tematiche di autenticazione a sfida simmetrica ed asimmetrica identificando chiaramente vantaggi e svantaggi di ciascuna di esse.

Un sistema a sfida è un processo di autenticazione che verifica un'identità richiedendo che siano fornite le informazioni di autenticazione corrette in risposta a una sfida.

Si dividono in due tipologie:

• simmetrici: l'utente conosce un segreto condiviso: dimostra di conoscere il segreto senza trasmetterlo, ma usandolo per effettuare un calcolo.

Pro e contro:

+ no sniffing

+ no replay (la sfida contiene un nonce)

- lato client, l'utente deve avere un funzione di hash per calcolare la risposta (non sempre possibile)

- il server non può memorizzare l'hash delle password, ma deve conoscerle in chiaro al fine di calcolare l'hash della soluzione

- la sfida passa in chiaro

• asimmetrici: l'utente conosce la sua chiave privata: dimostra di conoscere la chiave senza trasmetterla, ma usandola per effettuare un calcolo; la chiave privata non è condivisa: il server può compiere la verifica usando la chiave pubblica dell'utente.

Pro e contro:

+ la sfida è trasmessa cifrata

+ no attacchi di sniffing: non è possibile risalire alla chiave privata dell'utente;

+ no attacchi replay: la sfida contiene un numero nonce;

+ non necessaria riservatezza lato server: nessuna informazione riservata è memorizzata sul server.

- complessità computazionale al lato client

77. Cos'è una rainbow table?

Le rainbow table sono degli speciali database precalcolati che permettono di raggiungere un compromesso tra:

• memoria: solo un sottoinsieme degli hash è salvato nel database precalcolato

• tempo di calcolo: quando la catena viene trovata, occorre ripercorrere la catena per trovare la password

78. Spiegare il metodo della sfida asimmetrica elencando punti di forza e deboli del metodo e dei singoli componenti che partecipano.

Un sistema a sfida asimmetrica è un processo di autenticazione che verifica un'identità richiedendo che siano fornite le informazioni di autenticazione corrette in risposta a una sfida. L'utente conosce la sua chiave privata: dimostra di conoscere la chiave senza trasmetterla, ma usandola per effettuare un calcolo; la chiave privata non è condivisa: il server può compiere la verifica usando la chiave pubblica dell'utente.

Procedura di autenticazione

1. identificazione: il client invia il proprio certificato a chiave pubblica;

2. richiesta di una prova: il server genera un numero n nonce, lo cripta usando la chiave pubblica Kpub presa dal certificato

$$s=enc(Kpub, n)$$

e invia il numero criptato come sfida s;

3. prova: il client decripta la sfida s ricevuta usando la propria chiave privata Kpri e trasmette il numero in chiaro come soluzione alla sfida;

prova=dec(Kpri, s)

4. controllo: il server confronta la prova ricevuta con il numero generato *n*:

if(prova = n) then OK else ALARM

Pro e contro:

+ la sfida è trasmessa cifrata

+ no attacchi di sniffing: non è possibile risalire alla chiave privata dell'utente;

+ no attacchi replay: la sfida contiene un numero nonce;

+ non necessaria riservatezza lato server: nessuna informazione riservata è memorizzata sul server.

- complessità computazionale al lato client

79. Autenticazione a sfida asimmetrica

Un sistema a sfida asimmetrica è un processo di autenticazione che verifica un'identità richiedendo che siano fornite le informazioni di autenticazione corrette in risposta a una sfida. L'utente conosce la sua chiave privata: dimostra di conoscere la chiave senza trasmetterla, ma usandola per effettuare un calcolo; la chiave privata non è condivisa: il server può compiere la verifica usando la chiave pubblica dell'utente.

Procedura di autenticazione

1. identificazione: il client invia il proprio certificato a chiave pubblica;

2. richiesta di una prova: il server genera un numero n nonce, lo cripta usando la chiave pubblica Kpub presa dal certificato

s=enc(Kpub, n)

e invia il numero criptato come sfida s;

3. prova: il client decripta la sfida s ricevuta usando la propria chiave privata Kpri e trasmette il numero in chiaro come soluzione alla sfida;

prova=dec(Kpri, s)

4. controllo: il server confronta la prova ricevuta con il numero generato *n*:

if(prova = n) then OK else ALARM

Pro e contro:

+ la sfida è trasmessa cifrata

+ no attacchi di sniffing: non è possibile risalire alla chiave privata dell'utente;

+ no attacchi replay: la sfida contiene un numero nonce;

+ non necessaria riservatezza lato server: nessuna informazione riservata è memorizzata sul server.

- complessità computazionale al lato client

80. Spiegare cos'è un sistema di autenticazione a sfida asimmetrica, indicando quali messaggi vengono scambiati tra il client e il server che autentica e quali vantaggi e svantaggi presenta.

Un sistema a sfida asimmetrica è un processo di autenticazione che verifica un'identità richiedendo che siano fornite le informazioni di autenticazione corrette in risposta a una sfida. L'utente conosce la sua chiave privata: dimostra di conoscere la chiave senza trasmetterla, ma usandola per effettuare un calcolo; la chiave privata non è condivisa: il server può compiere la verifica usando la chiave pubblica dell'utente.

Procedura di autenticazione

1. identificazione: il client invia il proprio certificato a chiave pubblica;

2. richiesta di una prova: il server genera un numero n nonce, lo cripta usando la chiave pubblica Kpub presa dal certificato

s=enc(Kpub, n)

e invia il numero criptato come sfida s;

3. prova: il client decripta la sfida s ricevuta usando la propria chiave privata Kpri e trasmette il numero in chiaro come soluzione alla sfida;

prova=dec(Kpri, s)

4. controllo: il server confronta la prova ricevuta con il numero generato *n*:

if(prova = n) then OK else ALARM

Pro e contro:

+ la sfida è trasmessa cifrata

+ no attacchi di sniffing: non è possibile risalire alla chiave privata dell'utente;

+ no attacchi replay: la sfida contiene un numero nonce;

+ non necessaria riservatezza lato server: nessuna informazione riservata è memorizzata sul server.

- complessità computazionale al lato client

81. Spiegare che cosa è un sistema OTP time-based, indicando quali informazioni vengono trasmesse dal client al server di autenticazione e quale funzionalità è associata a ciascuna informazione trasmessa.

Nelle time-based OTP la password dipende dal tempo e dal segreto dell'utente: p(ID; t) = h(t; SID). E' richiesto inoltre un calcolo locale al claimant e la sincronizzazione dei clock. La password e ottenuta mediante un hash di tempo e segreto dell'utente.

82. Spiegare brevemente il concetto di OTP e quale problema di sicurezza risolve. Spiegare, quindi, con l'ausilio di appropriate formule, le fasi di inizializzazione e verifica nel protocollo S/KEY.

(Risposta dal professore)

Risolvono sniffing, MITM, replay.
S/KEY: inizializzazione sul server con l'ultima password PN = hN(s), verifica h(PN-1) = PN

83. Spiegare come funziona il timestamp (sicuro).

Capitolo 4
Lo standard X.509, le PKI ed i documenti elettronici

84. Che cos'è PKCS#10?

PKCS #10 è il formato standard usato da un utente per la richiesta di un certificato alla CA.
La richiesta PKCS #10 contiene:

• il distinguished name (DN) dell'utente richiedente;

• la chiave pubblica da certificare;

• eventuali attributi, tra cui:

– una password a sfida tramite la quale l'utente potrà in seguito richiedere la revoca del certificato;

– gli attributi (ad es. PKCS #9) che dovranno essere inseriti nel certificato;

– altre informazioni sul richiedente.

La richiesta PKCS #10 viene firmata con la chiave privata corrispondente alla chiave pubblica da certificare) la CA può verificare che il richiedente sia il legittimo titolare della chiave pubblica.

85. Che cosa è e per quale scopo è usato PKCS#11?

PKCS #11 è una API di sicurezza di basso livello che offre agli sviluppatori delle applicazioni un'interfaccia standard per accedere alle primitive del PSE di livello inferiore.
Fornisce un motore crittografico in grado di svolgere le operazioni di crittografia base (ad es. firma, criptazione), che è implementabile:

• in software: una libreria che implementa tutti gli algoritmi;

• in hardware: una libreria che è uno stub verso un PSE hardware

86. Dove si trova una CRL distribution point e cosa significa?

CRL distribution point (aka CRLDP o CDP) è un'estensione pubblica di un certificato X.509: identifica il punto di distribuzione della CRL da usare nella verifica della validita di un certificato. Puo essere una directory entry, e-mail o URL.
Può essere critica o non critica.

87. Dato un certificato X.509 spiegare quali sono le sue proprietà di sicurezza intrinseche e come sono ottenute.

Autenticazione e integrità tramite la firma della CA e la lista degli algoritmi usati per firmare.

88. Cos'è un certificato X.509? Elencare gli attributi.

X.509 è un certificato a chiave pubblica, ovvero una struttura dati usata per legare in modo sicuro una chiave pubblica ad alcuni attributi; permette di distribuire le chiavi pubbliche per usare le firme digitali in modo sicuro: la chiave pubblica del mittente non è fornita dal mittente, ma è fornita da un'entità esterna fidata attraverso un certificato a chiave pubblica, altrimenti un attaccante potrebbe spacciare la sua chiave pubblica come la chiave pubblica del mittente legittimo.

Un certificato X.509 versione 3 contiene, oltre alla firma digitale della CA, una sequenza di 10 elementi di dato, tra cui:

1. version: è la versione della codifica del certificato (= versione dello standard X.509 −1);

2. serialNumber: è un numero intero assegnato dalla CA, univoco per ogni certificato emesso da una CA data (cioè il nome dell'emettitore e il numero di serie identificano un certificato univoco);

3. signature: contiene l'identificativo di algoritmo dell'algoritmo e della funzione di hash usati dalla CA nella firma del certificato (ad es. sha1WithRSAEncryption);

4. issuer: è il **distinguished name** (DN) che identifica l'entità che ha firmato ed emesso il certificato (ad es. countryName=IT, stateOrProvinceName=Torino, organizationName=Politecnico di Torino, commonName=CA di prova);

5. validity: è l'intervallo di tempo, compreso tra notBefore e notAfter, in cui era valida la chiave privata corrispondente alla chiave pubblica che sta venendo certificata;

6. subject: è il DN che identifica l'entità associata con la chiave pubblica che sta venendo certificata (ad es. commonName=Antonio Lioy);

7. subjectPublicKeyInfo: trasporta il valore in chiaro della chiave pubblica che sta venendo certificata, e identifica l'algoritmo di cui questa chiave pubblica è un'istanza (ad es. rsaEncryption: esponente pubblico e modulo);

10. extensions (facoltativo): contiene eventuali estensioni specifiche del certificato.

89. Algoritmi a chiave simmetrica.

Nella crittografia simmetrica (o crittografia a chiave segreta), la chiave simmetrica è una chiave unica *K*, sia per la criptazione sia per la decriptazione, condivisa solo tra il mittente e il ricevente. La crittografia simmetrica richiede un carico di elaborazione minore rispetto alla crittografia asimmetrica, ed è quindi particolarmente adatta per criptare grosse quantità di dati.

Gli algoritmi simmetrici si suddividono in due classi:

• algoritmi a blocchi (ad es. DES, IDEA, RC2, RC5, AES): suddividono i dati da criptare in blocchi di eguale dimensione, quindi elaborano un blocco alla volta;

• algoritmi di tipo stream (ad es. RC4, SEAL): sono in grado di operare su un flusso di dati, un bit o un byte alla volta.

90. Lei riceve una penna usb contenente un file che deve passare ad un destinatario. Poiché i due peer la ritengono una persona non fidata il mittente calcola anche un digest per proteggere il file contro le modifiche e lo trasmette direttamente al destinatario. È noto che il digest venga calcolato prendendo i 24 bit più significativi dell'hash sha256 del file. Proponga una tecnica per modificare il file senza che i peer se ne accorgano e fornisca anche una stima del numero di operazioni necessarie.

Birthday attack, con un lowerbound di 2^(24/2) = 2^12 hash parto col 50% di probabilità di trovare una hash che fa collisione

91. Descrivere la tecnica della firma digitale ed elencare tutte le funzionalità di sicurezza offerte da essa, identificando quale componente del processo firma/verifica è fondamentale per le singole funzionalità. Spiegare anche il ruolo di un certificato X.509 in questo contesto.

Nella firma digitale viene calcolato un digest con un algoritmo crittografico e associato con un oggetto di dati in modo tale che qualsiasi destinatario dei dati può usare la firma per verificare l'origine e l'integrità dei dati

Proprietà di sicurezza:

+ integrità: se i dati in chiaro vengono modificati, il digest md*R* calcolato sui dati ricevuti sarà diverso dal digest md*F* ricevuto e decriptato;

+ autenticazione: solo chi conosce la chiave privata può aver generato una firma digitale corrispondente ai dati;

− riservatezza: i dati sono inviati in chiaro;

+ non ripudio: il mittente non può negare di aver firmato i dati, a patto che la sua chiave pubblica sia fornita da un certificato a chiave pubblica.

Nel contesto delle firme digitali, un cetificato X.509 serve per determinarne la validità e distribuirne la chiave pubblica associata in maniera autenticata.

92. Come avviene la verifica di un documento firmato?

- Verificare che il certificato sia nel periodo di validità (campi notBefore/notAfter)
- Verificare che il certificato non sia stato revocato (CRL/OCSP)
- Verificare la catena di certificati fino a un trusted root CA
- Verificate la firma decrittandola con la chiave pubblica presente nel certificato e confrontando il risultato con il digest del messaggio (sempre calcolato con l'algoritmo specificato nel certificato

93. Cos'è e a cosa serve PKCS#7?

PKCS #7, evolutosi poi in CMS (Cryptographic Message Syntax), è un formato che permette di creare buste sicure che possono contenere dati di qualsiasi tipo.

94. **Indicare gli errori di questa frase: ho un server che cifra i dati con certificato X.509 a 2048 bit, protetto con un reverse proxy che verifica le password con un algoritmo RIPEMD.**
Il certificato x.509 non è un algoritmo di cifratura ma uno standard per le certificazione dell'autenticità di un utente/host. Mentre RIPEMED è una funzione di hash che può essere utilizzata per verificare una password. Il reverse proxy non protegge ma fa solo forwarding.

    3 errori.

95. **PKCS#12, definizione.**
Si tratta di un formato dati utilizzato per memorizzare in maniera sicura coppie chiavi pubbliche-private. Concetto base è il trasporto di materiale crittografico (personale) tra applicazioni/sistemi diversi. Contiene al suo interno una chiave privata piu uno o piu certificati. Trasporta dunque una chiave privata e uno o piu certificati, e permette il trasporto dell'identità digitale di un utente.

96. **Descrivere il salvataggio di password lato server. Rischi e contromisure.**

97. **Quali sono le principali caratteristiche di una smart-card che la rendono interessante per le applicazioni di ICT?**

    (Risposta del professore)

    Protocollo storage KPR1, on board cryptography.

98. **A vuole mandare a B un file F di 100 MB, avendo le proprietà di sicurezza di riservatezza, autenticazione e integrità. A ha il certificato X.509 di B (la chiave pubblica). Non usare strutture dati complesse e descrivere i passaggi con i nomi dei protocolli piuttosto che con il generico.**
k=DH

    C=AES128_CBC(F,k,IV)

    K=RSA(k, Kpub) (Kpub from certifiate)

    D=HMAC_SHA256(Kpub, C || K || IV)

    send A and B, M=C || K || IV || D

99. **Cosa rappresentano le sigle TSA e TST?**

100. **Per un documento digitally signed: quali sono le possibilità (metodi)? Enveloping signature, enveloped, detached signature. Vantaggi e svantaggi.**
A livello concettuale, la firma digitale può essere allegata al documento in tre formati:

• enveloping signature (ad es. PKCS #7): la firma racchiude il documento, quindi il quest'ultimo va estratto prima di poter essere letto; ha come vantaggio quello di potere cifrare qualsiasi dato, ma come svantaggio c'e il fatto che bisogna modificare le applicazioni

• enveloped signature (ad es. PDF): il documento racchiude la firma, cioè il formato del documento prevede uno spazio per la firma; vantaggio è che la firma è wrappata nel documento, lo svantaggio è che si usa solo per il PDF

• detached signature (ad es. PKCS #7): il documento e la firma sono separati tra loro, e la firma contiene un riferimento (ad es. nome del file) al document; il vantaggio è la sua flessibilità, lo svantaggio è il riusire a mantenere nel tempo l'associazione tra la firma e il documento

101. **Se vogliamo inviare un messaggio PKCS#7 envelopedData a una persona, e a tre persone, cambierà la taglia del messaggio?**
Si, dato che la envelopedData contiene un campo info per ogni ricevente

Capitolo 5
Sicurezza delle reti IP

102. **Descrivere almeno due tipi di attacchi possibili con ICMP e le contromisure da adottare per evitare tali attacchi.**
Smurfing attack: viene mandato un pacchetto ICPM echo request broadcast ad un'intera sottorette fingedosi la vittima; la risposte ricevute dalla sottorette (detta anche reflector) causano una saturazione della scheda di rete della vittima. Per risolverlo bisogna far si di non accettare pacchetti broadcast da rete esterna.
ICMP redirect: un MITM intercetta un pacchetto da host A diretto verso un altro un host e risponde preventivamente con un ICMP redirect verso se stesso
103. **Spiegare l'ICMP redirect attack.**
Un MITM intercetta un pacchetto da host A diretto verso un altro un host e risponde preventivamente con un ICMP redirect verso se stesso

104. **Descrivere l'architettura basic VPN: che cos'è, l'implementazione, vantaggi e svantaggi.**
La basic-VPN e una soluzione piu leggera e permissiva, nella quale IPsec viene installata sui gateway e non sui dispositivi host. Si noti che i gateway

costituiscono dei colli di bottiglia e devono essere potenti al livello computazionale. Tale strategia si basa su un'importante ipotesi, cioe che una parte della rete sia considerata fidata. Fra le zone fidate e quelle non date viene collocato un gateway, punto in cui viene congurato appunto IPsec. Emerge la necessita di utilizzare TUNNEL.

105. Disegnare e discutere della End-to-end security with basic VPN

In una soluzione del genere, IPsec viene installato sia sui nodi host che sui gateway, e si puo utilizzare come doppia linea di difesa. Ad esempio, è possibile attivare AH sugli host e il tunnel mode sui gateway, garantendo una sorta di bilanciamento.

106. Un'azienda decide di collegare due sue filiali con una vpn del fipo basic VPN: dire caratteristiche, vantaggi e rischi

La basic-VPN è una soluzione leggera e permissiva, nella quale IPsec viene installata sui gateway e non sui dispositivi host. Si noti che i gateway costituiscono dei colli di bottiglia e devono essere potenti al livello computazionale. Tale strategia si base su un'importante ipotesi, cioe che una parte della rete sia considerata data. Fra le zone date e quelle non date viene collocato un gateway, punto in cui viene congurato appunto IPsec. Emerge la necessita di utilizzare TUNNEL.

107. Cos'è RADIUS, quali sono le caratteristiche di sicurezza e quale ruolo ha in una architettura di sicurezza.

Radius - Remote Authentication Dial-In User Service - è il piu diffuso protocollo di autenticazione, e supporta autenticazione, autorizzazione e accounting per l'accesso alla rete. L'integrita ed autenticazione dei pacchetti avviene tramite keyed-MD5. La key è shared-secret, mentre client senza key sono ignorati. Ogni pacchetto Radius ha un codice, un numero identicativo, una lunghezza su 16 bit, un autenticatore lungo 128 bit e poi ci sono gli attributi. L'autenticatore autentica la risposta del server ed evita replay. Inoltre, opera un calcolo per mascherare la password. RADIUS fa tendenzialmente da proxy verso altri server di autenticazione: se un utente si presenta al proprio server con un dominio adeguato, il server stesso gestisce l'autenticazione attraverso un DB locale; se viene utilizzato un dominio differente, occorre che il server RADIUS sia in qualche modo federato con il server del dominio cui si vuole fare accesso.

108. Quali sono i problemi di sicurezza del protocollo ICMP?

Il protocollo Internet Control and Management Protocol (ICMP) è vitale per la gestione della rete. Essendo privo di protezione è possibile avere moltissimi tipi di attacchi, in particolare:

• Un attaccante potrebbe sfruttare dei pacchetti destination unreachable (usati da un nodo intermedio per comunicare l'impossibilità di consegnare un pacchetto al destinatario) in modo da bloccare il traffico verso un nodo destinatario causando un

DoS. Questo perché al ricevimento di un pacchetto destination unreachable il nodo mittente interrompe la trasmissione dei pacchetti.

• Tramite un pacchetto source quence (usato per rallentare la trasmissione dei pacchetti quando i buffer di un nodo intermedio sono saturi) un attaccante può andare a diminuire la velocità di trasmissione del mittente, e quindi generare un DoS.

• Possibilità di usare i pacchetti redirect (usati da un nodo intermedio per comunicare ad un altro nodo la strada migliore da seguire per consegnare dei pacchetti) in modo da generare un attacco Man-In-The-Middle logico.

• Uso di un pacchetto time exceeded for a datagram (usato quando si genera un loop nella rete) in modo da generare un DoS e far cadere la connessione tra due nodi.

109. Cos'è un ARP spoofing attack?

Consiste nel modificare l'ARP table della vittima (magari usando strategie di replay o risposta preventiva), per poi impostare attacchi MITM

110. Dire che cos'è dns cache poisoning.

Gli attacchi DNS cache poisoning vengono utilizzati per attirare la vittima a fare una query sul proprio NS, e dunque attirare traco su un certo server.

Ha due versioni:

- La v1 consiste nel fornire una risposta anche a query non effettuate per forzare/sovrascrivere la cache della vittima. La risposta di un NS contiene dunque la traduzione anche di altri siti, che vengono salvati in cache poiché considerati piu "freschi". Si può evitare, ma parzialmente, effettuando un confronto sulla coerenza fra domanda e risposta.
- La v2 consiste nel fare una query e fornire subito, prima che il NS riesca a risolverla, la risposta (falsa) per inserirla nella cache della vittima. La risposta vera, che arriveràa in ritardo, sarà scartata.

111. DNS flash crowd: Spiegazione e contromisure

In un attacco del genere, molti nodi si collegano allo stesso tempo ad un server per metterlo fuori uso. Tale attacco e illegale solo se portato avanti attraverso dei bot. Il DNS ash crowd provoca un sovraccarico di request di un DNS server. Altro problema e costituito dalla traduzione nomi-indirizzi che ora non avviene più mediante sistemista ma in maniera automatica.

112. Ping flooding, cos'è e come difendersi in modo da non alterare il normale traffico tcp/ip

è un attacco di tipo DoS in cui si inviano in modo massivo messaggi ICMP Echo Request senza attenderne la risposta; come per tutti gli attacchi DoS, non esiste alcuna contromisura definitiva, ma solo dei rimedi palliativi basati sull'approccio quantitativo per mitigare gli effetti:

• monitoraggio: si cerca di rilevare eventuali anomalie (ad es. utilizzo delle risorse della CPU e di rete), anche se potrebbero essere originate da semplici malfunzionamenti;

• sovradimensionamento: si progetta il sistema per sopportare più carico di quello richiesto normalmente, così in caso di attacco DoS il sistema resiste per un po' di tempo, lasciando il tempo di identificare la sorgente dell'attacco.

113. Descrivere lo sniffing e almeno due modi di effettuarlo.

Per sniffing s'intende il rilevamento dei pacchetti in transito in una rete e la loro analisi per carpirne informazioni sensibili; al fine di contrastarlo è necessaria cifratura dei pacchetti. Si può effettuare sia in maniera logica, analizzando il traffico in una rete a cui si ha accesso, sia fisica, inserendo un dispositivo (ad es. switch) nei collegamenti della rete

114. Descrivere l'architettura VPN end-to-end: che cos'è, l'implementazione, vantaggi e svantaggi.

Questa architettura prende questo nome perché è quella in cui IPsec viene usato per proteggere il traffico direttamente fra due nodi client-server.

Questo significa che i due nodi su cui è stato installato il software IPsec negoziano tra di loro una SA in modalità transport mode. In altre parole i due nodi si creano un canale virtuale sicuro, con le caratteristiche di sicurezza che hanno negoziato, che rende la protezione del traffico da essi generato indipendente da tutto: non è importante se le LAN non sono sicure, se i gateway sono gestiti da persone non fidate o chi implementa o gestisce le WAN. Se le due macchine sono sicure allora si avrà la protezione completa del traffico di rete, ad eccezione del DoS.

Pro e contro:

\+ I due nodi sono completamente resi indipendenti e protetti da tutto il resto della rete, sia locale che geografica.

− È necessario andare ad installare IPsec su tutti i nodi della rete che si intende andare a proteggere; di conseguenza questa soluzione è usata principalmente quando si hanno pochi nodi da proteggere.

− Il fatto di andare ad installare IPsec sul singolo nodo presuppone che quel nodo abbia le capacità crittografiche necessarie; questo è molto importante per quanto riguarda il client, ma anche per quanto riguarda il server nel caso in cui il numero dei nodi fosse elevato.

− Nel caso che nel canale sia stato implementato riservatezza il gestore della rete locale non può andare a fare monitoraggio del traffico.

115. Che cos'è una S-VPN? Perchè ha questo nome?

Questo tipo di VPN (dove la S sta per Secure) si basa sull'utilizzo di un tunnel, ma i pacchetti prima di essere trasferiti vengono protetti. Questo viene fatto principalmente per proteggersi nei confronti del gestore della rete pubblica. I pacchetti possono essere protetti con:

• Digest, in modo da proteggere integrità e autenticazione. Questo evita che il gestore della rete possa modificare dei pacchetti o addirittura aggiungerne.

• Cifratura per la segretezza, in modo che non sia possibile leggere i pacchetti.

• Numerazione per evitare attacchi di tipo replay.

La cosa importante di questa tecnica è che la protezione deve essere fatta direttamente dal cliente della VPN, e non dal gestore. Se inoltre il cliente decide di utilizzare degli algoritmi crittografici forti, allora l'unico attacco possibile è impedire le comunicazioni mediante DoS.

116. Una azienda deve collegare due sue filiali con una VPN, quale infrastruttura si usa? Come è fatta? Disegnare lo schema, spiegare come viene configurata, vantaggi e svantaggi di questa soluzione.

117. Un'azienda decide di collegare due sue filiali con una VPN del fipo basic-vpn: dire caratteristiche, vantaggi e rischi

Questa architettura implementa l'idea opposta rispetto all'architettura precedente: invece di andare ad implementare IPsec sugli end-node, si presuppone che le reti locali siano fidate e che quelle pericolose siano solamente le reti geografiche. In base a questa idea IPsec viene installata sui gateway, ossia i punti di accesso fra due reti con livello di sicurezza differente: una rete sicura di cui ci si fida (nell'immagine è stata definita come LAN) e una di cui non si si fida (WAN).

Vantaggi e svantaggi:

+ Non occorre più andare a gestire un numero elevato di nodi, ma è sufficiente la gestione del solo gateway.

+ Se il gateway avesse dei problemi computazionali è possibile andare a prendere delle misure andando ad installare degli acceleratori crittografici.

+ La parte di rete fidata non essendo più cifrata può essere soggetta a monitoraggio.

− Non si ha più una protezione end-to-end. Questo significa che se c'è qualche malintenzionato all'interno della rete fidata questo è libero di eseguire qualunque tipo di attacco esso voglia.

118. Una azienda deve collegare due sue filiali con una IPsec del tipo VPN. Disegnare lo schema, spiegare come viene configurata, vantaggi e svantaggi di questa soluzione.

Questo tipo di VPN (detta anche S-VPN, dove la S sta per Secure) si basa sull'utilizzo di un tunnel, ma i pacchetti prima di essere trasferiti vengono protetti. Questo viene fatto principalmente per proteggersi nei confronti del gestore della rete pubblica. I pacchetti possono essere protetti con:

• Digest, in modo da proteggere integrità e autenticazione. Questo evita che il gestore della rete possa modificare dei pacchetti o addirittura aggiungerne.

• Cifratura per la segretezza, in modo che non sia possibile leggere i pacchetti.

• Numerazione per evitare attacchi di tipo replay.

La cosa importante di questa tecnica è che la protezione deve essere fatta direttamente dal cliente della VPN, e non dal gestore. Se inoltre il cliente decide di utilizzare degli algoritmi crittografici forti, allora l'unico attacco possibile è impedire le comunicazioni mediante DoS.

Pro e contro:

+ protegge il client dal gestore, e viceversa

+ l'unico attacco possibile è il DOS

+ prima di metterlo nel tunnel, l'utente può proteggere il pacchetto: digest (integrità e autenticazione), crittografia (riservatezza), numerazione (replay)

- suscettibile a DoS

119. EAP: a cosa serve, differenze rispetto a PAP e CHAP.

Il Extensible Authentication Protocol (EAP) è un protocollo flessibile di autenticazione a livello data-link.

La differenza rispetto a PAP e CHAP (che pure sono protocolli di autenticazione al livello 2) sta nella tecnica usata:

• PAP (Password Authentication Protocol): invia il nome utente e la password in chiaro;

• CHAP (Challenge Handshake Authentication Protocol): usa un sistema di autenticazione a sfida simmetrico, basato sulla password dell'utente;

• EAP (sez. 5.2): fornisce invece tre opzioni di autenticazione: OTP, token based e MD5- challenge(sistema a sfida simile a CHAP e basato su keyed-digest MD5)

120. Radius e quando si usa nelle reti wireless. Problemi di sicurezza in una piccola rete aziendale: che tecnologie adottare?

121. Cos'è IPsec e quali servizi di sicurezza offre.

IPsec è l'architettura proposta dall'IETF per fare sicurezza al livello 3 sia per IPv4 sia per IPv6.

IPsec permette di:

• Creare VPN su reti non fidate.

• Fare sicurezza end-to-end tra due nodi di una rete IP.

Proprietà di sicurezza:

• Autenticazione dei pacchetti IP

• Integrità dei dati trasportati.

• Identificazione del mittente.

• Protezione (parziale) da attacchi di tipo replay.

• Riservatezza dei pacchetti IP tramite cifratura dei dati

122. IPsec in transport mode con ESP: quali misure di sicurezza sono permesse (indicare quelle obbligatorie e quelle facoltative) e come vengono realizzate?

Integrità e autenticazione del pacchetto: keyed-digest
Riservatezza solo del payload: cifratura simmetrica
Protezione parziale replay: sequence number
Integrità+autenticazione (VPN-A) e cifratura(VPN-B) sono opzionali, nel senso che si può avere solo una delle due.

123. SA in transport-mode di tipo IPsec ESP, proprietà di sicurezza, dire quali proprietà di sicurezza sono obbligatorie e quali no (spiegazione)

Integrità e autenticazione del pacchetto: keyed-digest
Riservatezza solo del payload: cifratura simmetrica
Protezione parziale replay: sequence number
Integrità+autenticazione (VPN-A) e cifratura(VPN-B) sono opzionali, nel senso che si può avere solo una delle due.

124. Spiegare attacco smurfing.

viene mandato un pacchetto ICPM echo request broadcast ad un'intera sottorette fingedosi la vittima; la risposte ricevute dalla sottorette (detta anche reflector) causano una saturazione della scheda di rete della vittima. Per risolverlo bisogna far si di non accettare pacchetti broadcast da rete esterna.

125. Spiegare che cos'è 802.1x, identificare chiaramente quali sono i suoi componenti

Lo standard IEEE 802.1x definisce un'architettura generalizzata che fornisce un framework per effettuare:
• **autenticazione a livello MAC** (livello 2): l'accesso alla rete è limitato ai soli utenti abilitati tramite un'autenticazione richiesta dal dispositivo di rete stesso

• **key management**: sono necessarie delle chiavi per proteggere le comunicazioni (indispensabile per wireless)

Dal punto di vista architetturale si distinguono tre entità:

• **supplicant**: è il client dell'utente che "supplica" di avere accesso alla rete;

• **authenticator** (o etherNAS): è il punto di accesso alla rete aziendale o dell'ISP, cioè lo switch o l'access point wireless, che ha lo scopo di:

– bloccare l'accesso alla rete fino a quando il client non è stato autenticato con successo;

– fungere da proxy verso il server durante la fase di autenticazione;

• **server di autenticazione**: è l'AS RADIUS, che ha lo scopo di accettare o rifiutare le richieste di accesso.

126. **ESP: descrivere la procedura, le trasformazioni, come sono ottenute le informazioni richieste.**
Si aggiunge un IV da 64 bit, un payload di cui va fatto il padding, la cui lunghezza viene specificata. Inoltre, viene cifrato anche il tipo di payload. Viene autenticato tutto il pacchetto. Non viene cifrato tutto, bensì solo payload, padding length e payload type.

127. **Descrivere syn cookie e contro quale attacco è.**
Rappresenta l'unico sistema veramente efficace per evitare completamente il SYN flooding. L'idea è quella di usare dei SYN cookie, ossia utilizzare il sequence number del pacchetto SYN-ACK per trasmettere un cookie al client e riconoscere così i client che hanno già inviato il SYN senza memorizzare niente nel server. Tale sequence number sarà calcolato in maniera crittografica, ossia un keyed-digest calcolato sulla data, ora e indirizzo IP del client che ha inviato il SYN.

Capitolo 6
Firewall e IDS/IPS

128. **Un'azienda desidera rendere disponibile ai navigatori internet, un servizio http sulla porta 8080, indicare una configurazione della rete e/o del server per erogare il servizio in modo sicuro e spiegare il perché delle scelte adottate.**
Uso un firewall del tipo screened subnet con il giusto proxy web e web server sulla DMZ così da avere un buon livello di sicurezza dato da gateway, bastion e router con packet filtering, ma allo stesso tempo evitare SPOF dato il doppio controllo fatto sui paccheti

129. **Con riferimento ad un firewall di rete, spiegare brevemente le modalità di configurazione whitelist e blacklist**
Whitelist: tutto ciò che non è esplicitamente concesso, non passa
Blacklist: tutto ciò che non è esplicitamente vietato, non passa

Sono strategie implementate per decidere quale tipo di pacchetti far entrare(o uscire) dalla rete; tendenzialmente si preferisce la prima opzione perché più sicura.

130. **Descrivere l'architettura firewall screened host gateway indicando attori, vantaggi e svantaggi.**
Il ponte tra la rete interna e la rete esterna è spostato sullo screening router, a cui è stata aggiunta una scheda di rete: una volta che un pacchetto proveniente dall'esterno è autorizzato dal packet filter, esso può prendere due strade:

• può essere inviato ancora al gateway (ora diventato un bastion host), se ha bisogno di ulteriore indagine;

• può entrare direttamente nella rete interna, se ha bisogno di essere controllato da un server interno (ad es. server di posta).

Pro e contro:

+ flessibilità: è possibile alleggerire i controlli relativi ad alcuni servizi o host evitando di passare dal gateway.

- mascheramento: il mascheramento è possibile solo per i pacchetti che passano dal bastion host;

- singolo punto di guasto: il firmware del router potrebbe avere dei bug.

131. Descrivere la tecnologia del packet filter e descrivere vantaggi e limitazioni.

Consiste nel filtraggio dei pacchetti in entrata o uscita da un rete, e può essere stateless (static) o statefull (dinamic):
-static: si applica un filtraggio grossolano in base agli indirzzi di livello 3 e le porte di livello 4 con un sistema a blacklist o whitelist
-dinamic: memorizza delle informazioni di stato dal livello trasporto e/o dal livello applicativo; distingue le nuove connessioni da quelle già aperte, grazie a una tabella di stato per le connessioni aperte) i pacchetti che corrispondono ad una riga della tabella sono accettati senza ulteriori controlli.

Pro e contro:
+ molto scalabili
+ buone prestazioni (ma il dinamic leggermente migliore essendo statefull)
+ basso costo
- configurazioni complessa
- poco sicuri (controlli poco precisi)

132. Disegnare lo schema di un'architettura firewall di tipo dual homed gateway, illustrarne il ruolo dei componenti, vantaggi e svantaggi.

Allo screening router è messo in serie un dual-homed gateway, una macchina dotata di due schede di rete, una interfacciata sulla rete esterna e l'altra interfacciata su quella interna, entrambe con instradamento disabilitato, e un processo in esecuzione che ha il compito di decidere quale traffico è autorizzato a passare da un'interfaccia di rete all'altra. Questo sistema ha un doppio punto di controllo:

• il router svolge la funzione di packet filter;

• il dual-homed gateway ospita un circuit-level gateway o un application-level gateway a seconda delle necessità.

Siccome il gateway si interfaccia su due reti diverse, la rete intermedia è isolata dalla rete interna e può essere usata come DMZ per i server pubblici.

Pro e contro:

+ mascheramento: il gateway può mascherare la rete interna;

+ semplicità: l'implementazione è semplice;

+ costo: solo piccoli requisiti hardware aggiuntivi sono richiesti (ad es. scheda di rete veloce);

+ doppia linea di difesa: non basta sfruttare il bug di uno dei due dispositivi per entrare nella rete interna.

- gestione: sono necessari due sistemi;

- collo di bottiglia: tutto il traffico deve passare dal dual-homed gateway;

- flessibilità: alcuni tipi di traffico richiedono il controllo da parte di server nella rete interna (ad es. messaggi di posta elettronica di spam).

133. Packet filter e circuit gateway all'interno di un firewall: somiglianze, differenze, vantaggi e svantaggi di entrambi.

Entrambi compiono filtraggio dei pacchetti in base all'intestazione, ma il packet filter lavora al livello 3, mentre il circuit gateway al livello 4.

Packet filter: consiste nel filtraggio dei pacchetti in entrata o uscita da un rete, e può essere stateless (static) o statefull (dinamic):

-static: si applica un filtraggio grossolano in base agli indirzzi di livello 3 e le porte di livello 4 con un sistema a blacklist o whitelist
-dinamic: memorizza delle informazioni di stato dal livello trasporto e/o dal livello applicativo; distingue le nuove connessioni da quelle già aperte, grazie a una tabella di stato per le connessioni aperte) i pacchetti che corrispondono ad una riga della tabella sono accettati senza ulteriori controlli.

Pro e contro:
+ molto scalabili
+ buone prestazioni (ma il dinamic leggermente migliore essendo statefull)
+ basso costo
- configurazioni complessa
- poco sicuri (controlli poco precisi)

Circuit gateway: è un proxy non "application-aware" che crea un circuito di livello trasporto tra il client e il server senza avere alcuna comprensione della sintassi dei dati in transito

Pro e contro:
+ I server sono isolati da tutti gli attacchi che riguardano:
  - il three-way handshake TCP: la protezione si attiva all'inizio della sessione e dura per tutta la sessione;
  - la frammentazione dei pacchetti IP: il proxy riassembla il pacchetto per comprendere completamente il suo contenuto.

- rottura del modello client-server (per la durata della sessione): può richiedere modifiche alle applicazioni (ad es. autenticazione del client: avviene normalmente a livello applicativo, non a livello trasporto);

- rimangono molte limitazioni proprie del packet filter.

134. Packet filter e application level gateway all'interno di un firewall: somiglianze, differenze, vantaggi e svantaggi di entrambi.

Entrambi compiono filtraggio dei pacchetti in base all'intestazione, ma il packet filter lavora al livello 3, mentre l'application level gateway lavora al livello applicazione.

Packet filter: consiste nel filtraggio dei pacchetti in entrata o uscita da un rete, e può essere stateless (static) o statefull (dinamic):

-static: si applica un filtraggio grossolano in base agli indirzzi di livello 3 e le porte di livello 4 con un sistema a blacklist o whitelist
-dinamic: memorizza delle informazioni di stato dal livello trasporto e/o dal livello applicativo; distingue le nuove connessioni da quelle già aperte, grazie a una tabella di stato per le connessioni aperte) i pacchetti che corrispondono ad una riga della tabella sono accettati senza ulteriori controlli.

Pro e contro:
+ molto scalabili
+ buone prestazioni (ma il dinamic leggermente migliore essendo statefull)
+ basso costo
- configurazioni complessa
- poco sicuri (controlli poco precisi)

Application-level gateway: ispeziona i pacchetti a livello applicativo (payload): è composto al suo interno da una serie di proxy, uno per ogni protocollo applicativo; può svolgere il ruolo di terminatore: interagisce direttamente con il client come se fosse il server, e con il server come se fosse il client; può effettuare il mascheramento o la rinumerazione degli indirizzi IP: può essere necessario se sta agendo da terminatore e uno dei due party chiede l'autenticazione dell'altro; può anche avere funzioni di autenticazione, soprattutto in egress: il gateway chiede al client nella rete esterna di autenticarsi in modo da applicare a esso le politiche appropriate.

Pro e contro:

+ massima sicurezza: le regole sono più granulari e più semplici rispetto al packet filter, in quanto i controlli si basano sul livello applicativo;

+ parallelizzazione: più core della CPU lavorano in parallelo (SMP).

- prestazioni: controlli più approfonditi richiedono più tempo;

- dipendente dalle applicazioni: ogni protocollo applicativo richiede uno specifico proxy:

  – ritardo nel supporto di nuove applicazioni;

  – consumo di risorse: molti proxy significano molti processi;

  – basse prestazioni: i processi lavorano in user mode;

- rottura del modello client-server: può non essere del tutto trasparente ai client, e richiede spesso una modifica dell'applicativo client;

- attacchi: poiché il client interagisce direttamente con il gateway, il sistema operativo del firewall è esposto ad attacchi;

- protocolli di sicurezza di livello applicativo: il firewall potrebbe non essere in grado di interpretare correttamente il contenuto dei pacchetti (ad es. SSL: il contenuto del pacchetto è criptato).

135. Disegnare lo schema dello "Screened Subnet". Indicare il ruolo dei singoli componenti. Vantaggi e svantaggi di questo schema.

Lo screening router è stato diviso in due:

• la parte di packet filter filtra il traffico in ingresso e in uscita;

• la parte di router svolge la funzione di ponte tra le due reti.

Pro e contro:

+ flessibilità: è possibile alleggerire i controlli relativi ad alcuni servizi o host evitando di passare dal gateway;

+ doppia linea di difesa: non basta sfruttare il bug di uno dei due dispositivi per entrare nella rete interna.

- costo: sono necessari tre apparati;

- multi-vendor: gli apparati devono essere di tre produttori diversi, altrimenti potrebbero soffrire di bug comuni.

136. Parlare del firewall; dove si può piazzare in una grossa rete aziendale?

137. Cos'è il circuit gateway e da cosa protegge?

è un proxy non "application-aware" che crea un circuito di livello trasporto tra il client e il server senza avere alcuna comprensione della sintassi dei dati in transito

Pro e contro:

+ I server sono isolati da tutti gli attacchi che riguardano:

• il three-way handshake TCP: la protezione si attiva all'inizio della sessione e dura per tutta la sessione;

• la frammentazione dei pacchetti IP: il proxy riassembla il pacchetto per comprendere completamente il suo contenuto.

- rottura del modello client-server (per la durata della sessione): può richiedere modifiche alle applicazioni (ad es. autenticazione del client: avviene normalmente a livello applicativo, non a livello trasporto);

- rimangono molte limitazioni proprie del packet filter.

138. Classificazioni livelli dei firewall e controlli da fare a ogni livello; differenza packet filter e proxy di circuito.

Il proxy di circuito (reverse proxy) è un filtro ingress posto subito davanti a uno o più server HTTP: fa solo da front-end verso il client, fingendosi il server, e poi passa le richieste al vero server; il packet filter consiste nel filtraggio dei pacchetti in entrata o uscita da un rete al livello 3.

139. Architettura dei firewall (con schema), eventuali miglioramenti.

140. Cos'è IDS?

Intrusion Detection System (IDS) è un sistema per identificare individui che usano un computer o una rete senza autorizzazione

141. Qual è la principale differenza tra un IDS e un IPS?

IDS notifica se rileva un attacco, l'IPS cerca anche di bloccarlo

142. IDS vs IPS: cosa sono e differenze

Intrusion Detection System (IDS) è un sistema per identificare individui che usano un computer o una rete senza autorizzazione.

Intrusion Prevention System (IPS) è un sistema che può rilevare un'attività intrusiva e può anche provare a fermare l'attività, idealmente prima che essa raggiunga i suoi obiettivi.

La differenza è che IDS notifica se rileva un attacco, l'IPS cerca anche di bloccarlo.

143. Illustrare il funzionamento di un componente application-level gateway all'interno di un firewall e discuterne vantaggi e svantaggi.

Ispeziona i pacchetti a livello applicativo (payload): è composto al suo interno da una serie di proxy, uno per ogni protocollo applicativo;

può svolgere il ruolo di terminatore: interagisce direttamente con il client come se fosse il server, e con il server come se fosse il client; può effettuare il mascheramento o la rinumerazione degli indirizzi IP: può essere necessario se sta agendo da terminatore e uno dei due party chiede l'autenticazione dell'altro; può anche avere funzioni di autenticazione, soprattutto in egress: il gateway chiede al client nella rete esterna di autenticarsi in modo da applicare a esso le politiche appropriate.

Pro e contro:

+ massima sicurezza: le regole sono più granulari e più semplici rispetto al packet filter, in quanto i controlli si basano sul livello applicativo;

+ parallelizzazione: più core della CPU lavorano in parallelo (SMP).

- prestazioni: controlli più approfonditi richiedono più tempo;

- dipendente dalle applicazioni: ogni protocollo applicativo richiede uno specifico proxy:

  – ritardo nel supporto di nuove applicazioni;

  – consumo di risorse: molti proxy significano molti processi;

– basse prestazioni: i processi lavorano in user mode;

- rottura del modello client-server: può non essere del tutto trasparente ai client, e richiede spesso una modifica dell'applicativo client;

- attacchi: poiché il client interagisce direttamente con il gateway, il sistema operativo del firewall è esposto ad attacchi;

- protocolli di sicurezza di livello applicativo: il firewall potrebbe non essere in grado di interpretare correttamente il contenuto dei pacchetti (ad es. SSL: il contenuto del pacchetto è criptato).

144. Spiegare in cosa consiste la tecnica IPS.

Intrusion Prevention System (IPS) è un sistema che può rilevare un'attività intrusiva e può anche provare a fermare l'attività, idealmente prima che essa raggiunga i suoi obiettivi.

Un IPS è costituito da:

• IDS: rileva un attacco in corso (ad es. eccesso di pacchetti ICMP);

• firewall dinamico distribuito: reagisce molto velocemente (ad es. blocca tutto il traffico ICMP).

145. Per un'azienda che ha bisogno di avere un web server, un mail server, di fare access control (non tutti possono accedere a Internet), e di ispezionare il contenuto di tutto il traffico, disegnare un'architettura.

Capitolo 7
Sicurezza delle applicazioni di rete

146. **Proprietà di sicurezza di TLS con algoritmi e chiavi.**
A partire da TLS-1.2 abbiamo:
- PEER AUTHN: server obbligatoria, client opzionale. C/R ASYM implicita ed esplicita.
- RISERVATEZZA DATI: opzionali, SYM
- DATA AUTHN/INTEGRITÀ: obbligatorio, keyed-digest negoziata
- FILTERING: obbligatorio, MID implicito
- REPLAY: obbligatorio, MID implicito

Gli algoritmi usati sono HMAC per integrità, e per riservatezza DH + DSA + 3DES

147. **TLS, proprietà di sicurezza obbligatorie e facoltative, dire con quali algoritmi e con quali chiavi vengono realizzate**
A partire da TLS-1.2 abbiamo:
- PEER AUTHN: server obbligatoria, client opzionale. C/R ASYM implicita ed esplicita.
- RISERVATEZZA DATI: opzionali, SYM
- DATA AUTHN/INTEGRITÀ: obbligatorio, keyed-digest negoziata
- FILTERING: obbligatorio, MID implicito
- REPLAY: obbligatorio, MID implicito

Gli algoritmi usati sono HMAC per integrità, e per riservatezza **DH + DSA + 3DES**

148. **Quali sono gli step di trasformazione dei dati quando inviati tramite un canale TLS con la ciphersuite TLS_DHE_DSS_WITH_AES_128_CBC_SHA con ZIP**
1) frammentazione
2) compressione PACK.DATA = zip(PACK.DATA)
3) mac in questo caso un keyed digest utilizzando sha256 immagino quindi PACK.MAC = HMAC-SHA256(key_auth_client_to_server,packet) (considerando il padding se tls oppure senza considerarlo se ssl <= 2.0)
4) padding
5) generazione IV, quindi PACK.IV = rand(128)
6) cifratura utilizzando aes, quindi PACK.DATA = AES-128-CBC(PACK.IV,key_comp_client_to_server,PACK.DATA)
7) invio pacchetto, ovvero send(PACK) # che conterrà IV, DATA e MAC

149. **Descrivere come funziona la client authentication di TLS. Discutere i suoi vantaggi e i suoi svantaggi.**
1)certificate request(client): opzionale, richiesta dal server in fase di handshake
2)certificate(client): Trasporta il certificato per la client authentication. Il certificato deve essere stato emesso da una delle CA date elencate dal server nel messaggio Certicate Request.

3)Cetificate verify: Si tratta di una prova esplicita di firma. Viene verificato effettivamente che si possieda la chiave privata e che si intenda utilizzarla in tale contesto. L'hash è calcolato su tutti i messaggi di handshake che precedono questo ed e firmato con la chiave privata del client (serve per evitare impostori)

150. **TlS client authentication vs HTML form-based authentication: vantaggi, svantaggi e soluzioni**

TLS client auth: Nel caso in cui il canale SSL è stato attivato con client authentication, per autenticarsi l'utente dovrà fornire un certificato X.509, oltre a dover rispondere correttamente alla sfida. In quasto caso il server può effettuare un mapping per far sapere allo sviluppatore applicativo le credenziali dell'utente che ha richiesto accesso ad una determinata risorsa.

Il vantaggio è che l'attaccante potrà andare a sfruttare solamente i bachi contenuti all'interno di TLS; di conseguenza si avrà una superficie d'attacco molto piccola.

Lo svantaggio è che purtroppo questo molto spesso non è possibile perché gli utenti di rado hanno un certificato X.509, o anche nel caso in cui ce lo avessero non è detto che il sistemista abbia attivato la funzione di mapping delle credenzialità.

HTML form-based: il client invia i propri dati dopo averli inseriti in un form html

Lo svantaggio è che manda le credenziali semplicemente codificate in base64 e non vengono protette da crittografia quindi si può fare sniffing delle credenziali e il server deve anche stare attento a salvarle non in chiaro **mentre come vantaggio è che è veloce e facile da implementare.**

151. **Un'azienda vuole fare TLS client auth su un server web: vantaggi e svantaggi e accorgimenti da applicare su client e server.**
Vantaggi: autenticazione forte, superficie d'attacco ridotta, nessuna password memorizzata sul server, etc...
Lo svantaggio è che purtroppo questo molto spesso non è possibile perché gli utenti di rado hanno un certificato X.509, o anche nel caso in cui ce lo avessero non è detto che il sistemista abbia attivato la funzione di mapping delle credenzialità.

Accorgimenti: HSM sul server per metterci K privata, smart card o dispositivo sicuro per K privata sul client, HSTS e HPKP (che non c'entrano nulla con la client auth ma a quanto pare andavano detti).

152. **Un progettista web deve scegliere tra realizzare autenticazione degli utenti tramite TLS client authentication oppure HTLM form-based authentication. Illustrare le due soluzioni, con relativi vantaggi e svantaggi e quindi suggerire la soluzione migliore per generici utenti internet**
TLS client auth: Nel caso in cui il canale SSL è stato attivato con client authentication, per autenticarsi l'utente dovrà fornire un certificato X.509, oltre a dover rispondere correttamente alla sfida. In quasto caso il server può effettuare un mapping per far sapere allo sviluppatore applicativo le credenziali dell'utente che ha richiesto accesso ad una determinata risorsa.

Il vantaggio è che l'attaccante potrà andare a sfruttare solamente i bachi contenuti all'interno di TLS; di conseguenza si avrà una superficie d'attacco molto piccola.

Lo svantaggio è che purtroppo questo molto spesso non è possibile perché gli utenti di rado hanno un certificato X.509, o anche nel caso in cui ce lo avessero non è detto che il sistemista abbia attivato la funzione di mapping delle credenzialità.

HTML form-based: il client invia i propri dati dopo averli inseriti in un form html

Lo svantaggio è che manda le credenziali semplicemente codificate in base64 e non vengono protette da crittografia quindi si può fare sniffing delle credenziali e il server deve anche stare attento a salvarle non in chiaro mentre come vantaggio è che è veloce e facile da implementare.

Data che si parla di utenti generici che potrebbero essere privi di certificato, suggerirei la seconda, ovviamente con i dovuti accorgimenti.

153. Supponiamo di avere un sito web, come si potrebbe fare l'autenticazione dell'utente potendo agire solamente sul nodo di rete che ospita il sito web?

154. Considerando il protocollo TLS-1.0, spiegare quali proprietà di sicurezza offre e per ciascuna di esse indicare se è obbligatoria o opzionale e come viene ottenuta.

• **autenticazione del server** (obbligatoria): all'apertura del canale, il server:

1. si autentica inviando la propria chiave pubblica, tipicamente contenuta dentro un certificato X.509;

2. subisce una sorta di sfida asimmetrica per dimostrare di conoscere la chiave privata corrispondente alla chiave pubblica nel certificato;

• **autenticazione del client** (facoltativa): all'apertura del canale, il client si autentica nello stesso modo del server;

• **autenticazione e integrità dei messaggi** (obbligatorie): tutti i dati trasmessi sono protetti da MAC keyed-digest (ad es. SHA-2) (la firma digitale sarebbe troppo lenta per flussi di dati);

• **riservatezza dei messaggi** (facoltativa): tutti i dati trasmessi sono criptati con una chiave di sessione simmetrica (ad es. 3DES):

– il client decide la chiave;

– il client comunica la chiave al server tramite crittografia a chiave pubblica (ad es. RSA, DH);

• **protezione da attacchi replay e filtering**: ogni messaggio viene numerato con un MID3, garantendo una protezione completa possibile grazie al protocollo di trasporto affidabile (non parziale come in IPsec4):

- replay: i messaggi devono arrivare sempre nello stesso ordine con cui sono stati inviati e non devono essere duplicati;
- filtering (= cancellazione): non devono mancare dei messaggi.

• **protezione dei messaggi**: secondo vari studi il 10% dei messaggi necessita realmente di riservatezza (facoltativa), mentre il 100% necessita di autenticazione e integrità (obbligatorie).

155. Elencare e spiegare le caratteristiche di SSL.

SSL (Secure Socket Layer), proposto inizialmente da Netscape, è un protocollo per creare canali di trasporto sicuri. SSL giace approssimativamente al livello sessione, tra il livello di trasporto e il livello applicativo.

Caratteristiche:

• **autenticazione del server** (obbligatoria): all'apertura del canale, il server:

1. si autentica inviando la propria chiave pubblica, tipicamente contenuta dentro un certificato X.509;

2. subisce una sorta di sfida asimmetrica per dimostrare di conoscere la chiave privata corrispondente alla chiave pubblica nel certificato;

• **autenticazione del client** (facoltativa): all'apertura del canale, il client si autentica nello stesso modo del server;

• **autenticazione e integrità dei messaggi** (obbligatorie): tutti i dati trasmessi sono protetti da MAC keyed-digest (ad es. SHA-2) (la firma digitale sarebbe troppo lenta per flussi di dati);

• **riservatezza dei messaggi** (facoltativa): tutti i dati trasmessi sono criptati con una chiave di sessione simmetrica (ad es. 3DES):

– il client decide la chiave;

– il client comunica la chiave al server tramite crittografia a chiave pubblica (ad es. RSA, DH);

• **protezione da attacchi replay e filtering**: ogni messaggio viene numerato con un MID3, garantendo una protezione completa possibile grazie al protocollo di trasporto affidabile (non parziale come in IPsec4):

- replay: i messaggi devono arrivare sempre nello stesso ordine con cui sono stati inviati e non devono essere duplicati;
- filtering (= cancellazione): non devono mancare dei messaggi.

• **protezione dei messaggi**: secondo vari studi il 10% dei messaggi necessita realmente di riservatezza (facoltativa in SSL3), mentre il 100% necessita di autenticazione e integrità (obbligatorie).

156. Su un server HTTP è necessario autenticare i client, è possibile usare la client authentication di SSL oppure un form con ID e PSW su canale sicuro. Spiegare le due soluzioni, vantaggi e svantaggi di ognuna e dire qual è quella preferibile.

TLS client auth: Nel caso in cui il canale SSL è stato attivato con client authentication, per autenticarsi l'utente dovrà fornire un certificato X.509, oltre a

dover rispondere correttamente alla sfida. In quasto caso il server può effettuare un mapping per far sapere allo sviluppatore applicativo le credenziali dell'utente che ha richiesto accesso ad una determinata risorsa.

Il vantaggio è che l'attaccante potrà andare a sfruttare solamente i bachi contenuti all'interno di TLS; di conseguenza si avrà una superficie d'attacco molto piccola.

Lo svantaggio è che purtroppo questo molto spesso non è possibile perché gli utenti di rado hanno un certificato X.509, o anche nel caso in cui ce lo avessero non è detto che il sistemista abbia attivato la funzione di mapping delle credenzialità.

HTML form-based: il client invia i propri dati dopo averli inseriti in un form html

Lo svantaggio è che manda le credenziali semplicemente codificate in base64 e non vengono protette da crittografia quindi si può fare sniffing delle credenziali e il server deve anche stare attento a salvarle non in chiaro mentre come vantaggio è che è veloce e facile da implementare.

Sarebbe preferibile la prima al livello di sicurezza.

157. Approcci TLS-then-proto e proto-then-TLS: spiegare il funzionamento, vantaggi e svantaggi dei due approcci.

TLS then proto: ovvero prima viene aperto un canale sicuro e sucessivamente viene utilizzato il protocollo per il trasporto dei dati. La sicurezza non è gestita dal programmatore del server Web, ma è gestita dal sistemista: è compito di quest'ultimo attivare TLS prima di rendere accessibile l'applicazione Web. Questo ha il vantaggio di richiedere un minore lavoro agli sviluppatori, ma allo stesso tempo essi non avranno nessun controllo sui sistemi di sicurezza; occorrerà fidarsi dell'operato dei sistemisti. Occorre quindi avere una sincronizzazione tra il lavoro dei programmatori e quello dei sistemisti.

proto *then TLS:* In questo caso si ha l'apertura iniziale di un normale canale tramite protocollo, e sarà il server a decidere se si vuole fare sicurezza oppure no. Si ha quindi la possibilità di fare upgrading verso TLS di un normale canale. è lo sviluppatore che deve occuparsi della sicurezza: nel momento in cui un utente richiede di accedere a delle risorse protette occorre cessare il normale dialogo traite protocollo, trasformare il canale in sicuro e solo a quel punto potrà riprendere il dialogo. Questo si traduce in un carico di lavoro maggiore per lo sviluppatore in quanto dovrà occuparsi anche della sicurezza, ma ciò può anche essere visto come un vantaggio in quanto è lo sviluppatore stesso che controlla se e quale sicurezza si desidera avere.

Per quanto riguarda i firewall le due soluzioni non sono equivalenti principalmente per il motivo che esse utilizzano porte diverse.

Per quanto riguarda gli IDS, se si utilizza TLS then proto l'IDS sarà solamente in grado di vedere una richiesta di apertura di un canale protetto. Una volta che il canale sarà aperto non sarà più possibile vedere nulla.

Con proto then TLS invece l'IDS può vedere che il canale è stato creato e che per una specifica richiesta il server ha deciso di trasformare il canale in sicuro. L'IDS non sarà comunque in grado di vedere nulla fintanto che TLS sarà attivo, ma almeno si ha un controllo su quali URL viene attivata la sicurezza.

158. **Che cosa sono gli step di trasformazione dei dati quando inviati tramite un canale TLS con la cipher suite DHE-RSA-AES-128-SHA?**
Segmentation, compressione, calcolo del MAC con SHA-1, aggiunto del padding, creazione dell'IV, cifratura con AES, aggiunta dell'header.

159. **Come si può garantire l'autenticazione del traffico HTTP?**

160. **Spiegare Heartbleed**
Heartbleed è un possibile attacco che consiste nel tenere continuamente aperta una connessione senza rinegoziare una sessione SSL. In questo modo un attaccante puo ottenere dati sensibili presenti in un dato blocco di RAM, quali user+pwd e/o chiave privata del server tramite buffer-overflow (se non si usa un HSM, il server tiene la chiave privata in RAM). Si basa sull'estensione Heartbeat che, una volta aperto un canale TLS, continua a scambiare messaggi, anche vuoti, per mantenere la connessione aperta.

161. **Indicare quali proprietà di sicurezza sono disponibili tramite il protocollo TLS-1.2. Per ciascuna proprietà indicare se è opzionale o meno, la metodologia usata per implementarla e le eventuali chiavi specifiche o altri parametri di configurazioni necessari.**

(Risposta dal professore)

- PEER AUTHN: server obbligatoria, client opzionale. C/R ASYM implicita ed esplicita.
- RISERVATEZZA DATI: opzionali, SYM
- DATA AUTHN/INTEGRITÀ: obbligatorio, keyed-digest negoziata
- FILTERING: obbligatorio, MID implicito
- REPLAY: obbligatorio, MID implicito

162. **Si vuole controllare l'accesso alle pagine web ospitate da un server operando solo sulla configurazione del server stesso. Identificare le possibili tecniche utilizzabili, indicandone vantaggi e svantaggi.**

(Risposta del professore)

- INGRESS: semplice, livello S1. svantaggi: IP spoofing, no per-page
- IP-SEC: livello S2. svantaggi: configurare anche il client, no per-page
- TLS c/authn: livello S3, per-page. svantaggi: client certificate che non tutti hanno.
- HTTP basic/digest: semplice, per-page. svantaggi: livello S4, se basic -> TLS (per evitare sniffing)
- FORM based authn: integrità nell'applicazione. svantaggi: livello S5, la forza effettiva dipende dalla tecnica utilizzata.

Capitolo 8
Sicurezza della posta elettronica

163. Quali sono le proprietà di sicurezza di S/MIME clear-signed? Spiegare indicando gli opportuni algoritmi usati e dire se sono obbligatori o opzionali.

Le proprietà offerte sono:

• Non ripudio: tramite f*irma per ricevuta di un documento*, in modo che il destinatario di un messaggio non possa negare di averlo ricevuto.

• *Security label*, meccanismo attraverso il quale si va a classificare ogni messaggio secondo una certa gerarchia di sicurezza. Ad esempio in ambito militare i messaggi vengono classificati in unclassified (leggibili da chiunque), classified (riservati solo a coloro che hanno una certa autorizzazione), secret e top-secret.

• *Mailing-list sicure*, che permette di risolvere il problema di come fare a cifrare i messaggi destinati ad una mailing-list (dove non si ha a disposizione le chiavi pubbliche dei destinatari). Questo però introduce una debolezza perché il messaggio non è più cifrato end-to-end ma il gestore della mailing list potrebbe potenzialmente andare a leggerne il contenuto.

• *Firma degli attributi dei certificati*.

Gli algoritmi usati sono:
• Digest: SHA-1 (obbligatorio) o MD5.

• Firma digitale: DSS (obbligatorio) o digest+RSA (soluzione più usata).

• Scambio chiavi: Diffie Hellman (obbligatorio). In realtà la pratica comune è quella di calcolare una chiave di messaggio cifrandola con la chiave RSA del destinatario.

• Cifratura del messaggio: 3DES o RC2/40 (entrambi obbligatori).

164. Indicare con una formula la struttura di un messaggio S/MIME per un testo T ed una coppia di chiavi (Kpri, Kpub)

165. Dire che cosa ha in più APOP rispetto a POP e come lo implementa
La variante APOP introduce un nuovo comando, chiamato appunto APOP, che sostituisce la coppia di comandi USER + PASS. Questo comando introduce un meccanismo a sfida di tipo simmetrico.

166. Descrivere gli attributi di S/MIME clear-signed indicando quali sono opzionali e descrivere i vari algoritmi di cifratura e le chiavi usate.
• Digest: SHA-1 (obbligatorio) o MD5.

• Firma digitale: DSS (obbligatorio) o digest+RSA (soluzione più usata).

• Scambio chiavi: Diffie Hellman (obbligatorio). In realtà la pratica comune è quella di calcolare una chiave di messaggio cifrandola con la chiave RSA del destinatario.

• Cifratura del messaggio: 3DES o RC2/40 (entrambi obbligatori).

167. Con riferimento ad un sistema di gestione della posta elettronica Internet (MHS, Mail Handling System) identificare i possibili problemi di sicurezza ed indicare quali tecniche di protezione si possono applicare per risolvere o mitigare ciascun problema.
Sicurizzare la posta elettronica non è banale:

• Sistema connectionless, ossia non si ha un collegamento diretto tra il mittente e il destinatario. Anzi si parla di sistema *store-and-forward*, ossia il messaggio prima di essere inviato da un nodo all'altro viene prima salvato in locale e solo in un secondo momento viene inoltrato.

• Uso di MTA non fidati su cui si va a memorizzare (anche se temporaneamente) i messaggi.

• Livello di sicurezza del MS sul quale si va a memorizzare i messaggi prima che essi vengano letti.

• Si potrebbe implementare un sistema di cifratura, ma si avrebbero dei problemi nel caso in cui si usasse una mailing-list (problema di implementare la cifratura per tutti gli appartenenti della mailing-list).

• Poiché la posta elettronica è ormai un sistema di largo utilizzo, apportare delle modifiche non è una cosa così semplice da fare.

168. S/MIME: indicare gli algoritmi di cifratura, hashing e firma, sia obbligatori che opzionali, ed indicare come ciascuno di essi viene utilizzato all'interno di S/MIME.

• Digest: SHA-1 (obbligatorio) o MD5.

• Firma digitale: DSS (obbligatorio) o digest+RSA (soluzione più usata).

• Scambio chiavi: Diffie Hellman (obbligatorio). In realtà la pratica comune è quella di calcolare una chiave di messaggio cifrandola con la chiave RSA del destinatario.

• Cifratura del messaggio: 3DES o RC2/40 (entrambi obbligatori).

169. Dove è meglio fare l'autenticazione del mittente in un sistema di posta tra MTA e MSA?

Authn al MSA nei confronti dei suoi utenti

170. Funzionamento del PGP e perché alla gente non piace.

PGP è un sistema per fare autenticazione, integrità e riservatezza di dati generici. Le chiavi sono conservate personalmente da ogni utente nel cosiddetto key-ring. Esse sono distribuite direttamente dai proprietari, ad esempio all'interno dei famosi PGP party, oppure andando a caricarle all'interno di un key-server.

PGP è stato integrato in molti sistemi di posta elettronica, e si è anche avuto qualche tentativo di introduzione nel mercato aziendale. Ma alle aziende non piace molto l'idea dei PGP party.

171. PGP, dire caratteristiche, vantaggi e svantaggi

PGP è un sistema per fare autenticazione, integrità e riservatezza di dati generici: non usa certificati X.509, ma usa uno schema di certificazione delle chiavi molto peculiare in cui si parla di amici (fidati e non fidati), e di usare un algebra di propagazione della fiducia; le chiavi sono conservate personalmente da ogni utente nel cosiddetto key-ring. Esse sono distribuite direttamente dai proprietari, ad esempio

all'interno dei famosi PGP party, oppure andando a caricarle all'interno di un key-server.

Lo svantaggio principale sta nel sistema di distribuzione delle chiavi, non ritenuto abbastanza sicuro.

172. S/MIME: breve descrizione.

S/MIME è il principale standard oggi usato per la sicurezza dei messaggi MIME, e offre funzionalità di firma digitale e di cifratura tramite l'utilizzo di certificati X.509v3.

173. Con riferimento all'anti-spam per le MTA in ingresso, descrivere nolisting, greylisting, basato su DNS, i loro vantaggi e svantaggi.

DNSBL (DNS blacklists and whitelists): il suo funzionamento è il seguente: si riceve una richiesta di collegamento da parte di un MTA esterno, avente indirizzo A.B.C.D, e si verifica se questo indirizzo è noto per spedire spam eseguendo un'operazione di lookup DNS; lo svantaggio è che una volta entrati in una lista, è difficile uscirne

Greylisting un mail server che utilizza questa tecnica rifiuterà temporaneamente tutte le e-mail da un mittente che non conosce. Se l'e-mail è legittima, il mail server del mittente ritenterà l'invio, e questa volta l'operazione verrà accettata. Se l'e-mail viene inviata da uno spammer, probabilmente non si avrà un ulteriore tentativo poiché il mail server dello spammer avendo a disposizione migliaia (o milioni) di indirizzi email, passerebbe oltre non occupandosi degli errori. Questa tecnica ha il grosso svantaggio di ritardare non soltanto le mail di spam, ma anche qualunque messaggio di posta elettronica si riceva.

Nolisting: è sempre basata sulla teoria che gli spammer non hanno tempo da perdere, e quindi non vanno a provare tutti gli MX (Mail eXchanger, ossia un'incoming MTA nella terminologia dei DNS) definiti per ciascun dominio. In particolare i domini che utilizzano questa tecnica vanno a definire tre diversi MX:

• 1 MX: non risponde mai.

• 2 MX: funziona regolarmente.

• 3 MX: non risponde mai.

Questo viene fatto perché solitamente gli spammer utilizzano il primo o il terzo MX, non li provano tutti. Questa tecnica ha il vantaggio di bloccare, o comunque ritardare, gli spammer ma causa anche un ritardo delle mail. Si ha però il vantaggio di non sovraccaricare ulteriormente l'MTA perché si andrà a ricevere solamente la posta valida.

174. Spiegare tre tecniche anti-spam per incoming MTA, identificandone per ognuna vantaggi e svantaggi (come precedente)

DNSBL (DNS blacklists and whitelists): il suo funzionamento è il seguente: si riceve una richiesta di collegamento da parte di un MTA esterno, avente indirizzo

A.B.C.D, e si verifica se questo indirizzo è noto per spedire spam eseguendo un'operazione di lookup DNS; lo svantaggio è che una volta entrati in una lista, è difficile uscirne

Greylisting un mail server che utilizza questa tecnica rifiuterà temporaneamente tutte le e-mail da un mittente che non conosce. Se l'e-mail è legittima, il mail server del mittente ritenterà l'invio, e questa volta l'operazione verrà accettata. Se l'e-mail viene inviata da uno spammer, probabilmente non si avrà un ulteriore tentativo poiché il mail server dello spammer avendo a disposizione migliaia (o milioni) di indirizzi email, passerebbe oltre non occupandosi degli errori. Questa tecnica ha il grosso svantaggio di ritardare non soltanto le mail di spam, ma anche qualunque messaggio di posta elettronica si riceva.

Nolisting: è sempre basata sulla teoria che gli spammer non hanno tempo da perdere, e quindi non vanno a provare tutti gli MX (Mail eXchanger, ossia un'incoming MTA nella terminologia dei DNS) definiti per ciascun dominio. In particolare i domini che utilizzano questa tecnica vanno a definire tre diversi MX:

• 1 MX: non risponde mai.

• 2 MX: funziona regolarmente.

• 3 MX: non risponde mai.

Questo viene fatto perché solitamente gli spammer utilizzano il primo o il terzo MX, non li provano tutti. Questa tecnica ha il vantaggio di bloccare, o comunque ritardare, gli spammer ma causa anche un ritardo delle mail. Si ha però il vantaggio di non sovraccaricare ulteriormente l'MTA perché si andrà a ricevere solamente la posta valida.

175. Comando AUTH di ESMTP

176. Autenticare il mittente di posta elettronica: MS, MSA o MTA?
MSA

177. Con riferimento ai formati per la creazione di un documento elettronico con firma digitale, descrivere le soluzioni disponibili e discuterne i relativi vantaggi e svantaggi.

(Risposta del professore)

- Enveloping signature (PKCS #7)

vantaggi: applicabile su tutti gli oggetti
svantaggi: bisogna modificare le applicazioni

- Enveloped signature (PDF)

vantaggi: wrapping/wrapper

svantaggi: utilizzabile solo per quell’applicazione

- Detached signature (PKCS #7)

vantaggi: applicabile su tutti gli oggetti
svantaggi: link tra firma e documento

Capitolo X
Domande non ancora catalogate

178. Un consulente propone di basare l'auth sul login invece di usare HTML, discutere

Sicurezza dei sistemi informativi – Esame 03/04/2023

1) Cosa è 3DES?
   a) Un algoritmo di crittografia asimmetrica
   b) Un algoritmo di crittografia simmetrica a blocchi con chiave da 160 bit e blocco da 64
   c) Un algoritmo di crittografia simmetrica a blocchi con chiave da 56 bit e blocco da 64
   d) Un algoritmo di crittografia simmetrica di tipo stream
   e) Nessuna delle precedenti

2) Cosa è l'offuscamento del software?
   a) Una tecnica per rendere il codice binario illeggibile per i dissassemblatori e quindi più difficilmente attaccabile
   b) Nessuna delle precedenti
   c) Una tecnica che permette di rallentare gli attaccanti perché rende il codice più lungo e complesso quindi più difficile sia da comprendere che da modificare
   d) Una famiglia di tecniche che permettono di rallentare gli attaccanti perché rendono il codice più complesso quindi più difficile da modificare.
   e) Una famiglia di tecniche che permettono di rallentare gli attaccanti perché rendono la fruizione e comprensione del software più difficile.

3) Cosa è un SOC?
   a) È un sistema di gestione degli attacchi che usa eventi e metodi attivi.
   b) È un sistema di monitoring che permette l'interazione automatica con sistemi di difesa, es. i firewall mediante la gestione degli eventi e delle operazioni.
   c) Nessuna delle precedenti.
   d) È una soluzione che serve a garantire la sicurezza delle operazioni aziendali.
   e) È un dipartimento che si occupa di gestire e identificare, gestire e mitigare le minacce oltre a rispondere agli incidenti.

4) Indicare e motivare brevemente quale controllo, tecnologia o architettura di sicurezza utilizzereste nel caso fosse necessario implementare delle policy di sicurezza per:
   1. scoprire in tempo reale o nel Di breve tempo possibile se e in corso un attacco nella mia rete locale
   2. autenticare ali utenti aziendali prima di permettere loro di accedere ad Internet:
   3. evitare che alcuni host, descritti mediante una blacklist di URL, riescano a raggiungere un server aziendale
   4. permettere agli utenti di un'azienda di usare da casa dei servizi aziendali non accessibili all'esterno della rete privata aziendale

5) Spiegare cosa è e come funziona il ransomware.
   Spiegare che impatto hanno sulle vittime e i vantaggi per ali attaccanti.
   Suggerire due contromisure, una per evitarlo o e l'altra per mitigare al massimo le conseguenze di tali attacchi.

6) Indicare quali proprietà di sicurezza possono essere applicate al traffico usando IPsec (v2) AH in funzione dei modi di utilizzo
   Per ognuna delle proprietà indicate, riportare se sono obbligatorie o opzionali e a quale parte del pacchetto IP originale si applicano
   ATTENZIONE: al pacchetto originale!

7) Spiegare cosa sono e quali proprietà garantiscono MAC e firma digitali.
   Spiegare quali operazioni devono essere svolte e con guai segreti devono essere usati per calcolarli
   Spiegate i vantaggi e svantaggi relativi.
   Scegliete la tecnica da usare per proteggere dati un server pubblico.

8) Spiegate cosa è il GDPR, quale è il suo obiettivo e indicare almeno 4 dei principi che lo caratterizzano trattamenti e servizi (indicando a quali si applicano)